

Protect Account Data

Requirement 3: Protect Stored Account Data

Sections

- 3.1** Processes and mechanisms for protecting stored account data are defined and understood.
- 3.2** Storage of account data is kept to a minimum.
- 3.3** Sensitive authentication data (SAD) is not stored after authorization.
- 3.4** Access to displays of full PAN and ability to copy PAN are restricted.
- 3.5** Primary account number (PAN) is secured wherever it is stored.
- 3.6** Cryptographic keys used to protect stored account data are secured.
- 3.7** Where cryptography is used to protect stored account data, key management processes and procedures covering all aspects of the key lifecycle are defined and implemented.

Overview

Protection methods such as encryption, truncation, masking, and hashing are critical components of account data protection. If an intruder circumvents other security controls and gains access to encrypted account data, the data is unreadable without the proper cryptographic keys and is unusable to that intruder. Other effective methods of protecting stored data should also be considered as potential risk-mitigation opportunities. For example, methods for minimizing risk include not storing account data unless necessary, truncating cardholder data if full PAN is not needed, and not sending unprotected PANs using end-user messaging technologies such as e-mail and instant messaging.

If account data is present in non-persistent memory (for example, RAM, volatile memory), encryption of PAN is not required. However, proper controls must be in place to ensure that memory maintains a non-persistent state. Data should be removed from volatile memory once the business purpose (for example, the associated transaction) is complete. In the case that data storage becomes persistent, all applicable PCI DSS Requirements will apply including encryption of stored data.

Requirement 3 applies to protection of stored account data unless specifically called out in an individual requirement.

Refer to [Appendix G](#) for definitions of “strong cryptography” and other PCI DSS terms.

Requirements and Testing Procedures		Guidance
3.1 Processes and mechanisms for protecting stored account data are defined and understood.		
Defined Approach Requirements 3.1.1 All security policies and operational procedures that are identified in Requirement 3 are: • Documented. • Kept up to date. • In use. • Known to all affected parties.	Defined Approach Testing Procedures 3.1.1 Examine documentation and interview personnel to verify that security policies and operational procedures identified in Requirement 3 are managed in accordance with all elements specified in this requirement.	Purpose Requirement 3.1.1 is about effectively managing and maintaining the various policies and procedures specified throughout Requirement 3. While it is important to define the specific policies or procedures called out in Requirement 3, it is equally important to ensure they are properly documented, maintained, and disseminated. Good Practice It is important to update policies and procedures as needed to address changes in processes, technologies, and business objectives. For this reason, consider updating these documents as soon as possible after a change occurs and not only on a periodic cycle. Definitions Security policies define the entity's security objectives and principles. Operational procedures describe how to perform activities, and define the controls, methods, and processes that are followed to achieve the desired result in a consistent manner and in accordance with policy objectives.
Customized Approach Objective Expectations, controls, and oversight for meeting activities within Requirement 3 are defined and adhered to by affected personnel. All supporting activities are repeatable, consistently applied, and conform to management's intent.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.1.2 Roles and responsibilities for performing activities in Requirement 3 are documented, assigned, and understood.	Defined Approach Testing Procedures 3.1.2.a Examine documentation to verify that descriptions of roles and responsibilities performing activities in Requirement 3 are documented and assigned. 3.1.2.b Interview personnel with responsibility for performing activities in Requirement 3 to verify that roles and responsibilities are assigned as documented and are understood.	Purpose If roles and responsibilities are not formally assigned, personnel may not be aware of their day-to-day responsibilities, and critical activities may not occur. Good Practice Roles and responsibilities may be documented within policies and procedures or maintained within separate documents. As part of communicating roles and responsibilities, entities can consider having personnel acknowledge their acceptance and understanding of their assigned roles and responsibilities. Examples A method to document roles and responsibilities is a responsibility assignment matrix that includes who is responsible, accountable, consulted, and informed (also called a RACI matrix).
Customized Approach Objective Day-to-day responsibilities for performing all the activities in Requirement 3 are allocated. Personnel are accountable for successful, continuous operation of these requirements.		

Requirements and Testing Procedures		Guidance
3.2 Storage of account data is kept to a minimum.		
Defined Approach Requirements 3.2.1 Account data storage is kept to a minimum through implementation of data retention and disposal policies, procedures, and processes that include at least the following: - Coverage for all locations of stored account data. - Coverage for any sensitive authentication data (SAD) stored prior to completion of authorization. <i>This bullet is a best practice until its effective date; refer to Applicability Notes below for details.</i> - Limiting data storage amount and retention time to that which is required for legal or regulatory, and/or business requirements. - Specific retention requirements for stored account data that defines length of retention period and includes a documented business justification. - Processes for secure deletion or rendering account data unrecoverable when no longer needed per the retention policy. - A process for verifying, at least once every three months, that stored account data exceeding the defined retention period has been securely deleted or rendered unrecoverable.	Defined Approach Testing Procedures 3.2.1.a Examine the data retention and disposal policies, procedures, and processes and interview personnel to verify processes are defined to include all elements specified in this requirement. 3.2.1.b Examine files and system records on system components where account data is stored to verify that the data storage amount and retention time does not exceed the requirements defined in the data retention policy. 3.2.1.c Observe the mechanisms used to render account data unrecoverable to verify data cannot be recovered.	Purpose A formal data retention policy identifies what data needs to be retained, for how long, and where that data resides so it can be securely destroyed or deleted as soon as it is no longer needed. The only account data that may be stored after authorization is the primary account number or PAN (rendered unreadable), expiration date, cardholder name, and service code. The storage of SAD data prior to the completion of the authorization process is also included in the data retention and disposal policy so that storage of this sensitive data is kept to minimum, and only retained for the defined amount of time. Good Practice When identifying locations of stored account data, consider all processes and personnel with access to the data, as data could have been moved and stored in different locations than originally defined. Storage locations that are often overlooked include backup and archive systems, removable data storage devices, paper-based media, and audio recordings. To define appropriate retention requirements, an entity first needs to understand its own business needs as well as any legal or regulatory obligations that apply to its industry or to the type of data being retained. Implementing an automated process to ensure data is automatically and securely deleted upon its defined retention limit can help ensure that account data is not retained beyond what is necessary for business, legal, or regulatory purposes. <i>(continued on next page)</i>
Customized Approach Objective Account data is retained only where necessary and for the least amount of time needed and is securely deleted or rendered unrecoverable when no longer needed.		

Requirements and Testing Procedures		Guidance
Applicability Notes Where account data is stored by a TPSP (for example, in a cloud environment), entities are responsible for working with their service providers to understand how the TPSP meets this requirement for the entity. Considerations include ensuring that all geographic instances of a data element are securely deleted. <i>The bullet above (for coverage of SAD stored prior to completion of authorization) is a best practice until 31 March 2025, after which it will be required as part of Requirement 3.2.1 and must be fully considered during a PCI DSS assessment.</i>		Methods of eliminating data when it exceeds the retention period include secure deletion to complete removal of the data or rendering it unrecoverable and unable to be reconstructed. Identifying and securely eliminating stored data that has exceeded its specified retention period prevents unnecessary retention of data that is no longer needed. This process may be automated, manual, or a combination of both. The deletion function in most operating systems is not “secure deletion” as it allows deleted data to be recovered, so instead, a dedicated secure deletion function or application must be used to make data unrecoverable. <i>Remember, if you don't need it, don't store it!</i> Examples An automated, programmatic procedure could be run to locate and remove data, or a manual review of data storage areas could be performed. Whichever method is used, it is a good idea to monitor the process to ensure it is completed successfully, and that the results are recorded and validated as being complete. Implementing secure deletion methods ensures that the data cannot be retrieved when it is no longer needed. Further Information See NIST SP 800-88 Rev. 1, <i>Guidelines for Media Sanitization</i>.

Requirements and Testing Procedures		Guidance
3.3 Sensitive authentication data (SAD) is not stored after authorization.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
3.3.1 SAD is not stored after authorization, even if encrypted. All sensitive authentication data received is rendered unrecoverable upon completion of the authorization process.	3.3.1.a If SAD is received, examine documented policies, procedures, and system configurations to verify the data is not stored after authorization.	SAD is very valuable to malicious individuals as it allows them to generate counterfeit payment cards and create fraudulent transactions. Therefore, the storage of SAD upon completion of the authorization process is prohibited.
Customized Approach Objective	3.3.1.b If SAD is received, examine the documented procedures and observe the secure data deletion processes to verify the data is rendered unrecoverable upon completion of the authorization process.	Good Practice
This requirement is not eligible for the customized approach.		It may be acceptable for an entity to store SAD in non-persistent memory for a short time after authorization is complete, if following conditions are met:
Applicability Notes		• There is a legitimate business need to access SAD in memory after authorization is complete. • SAD is only ever stored in non-persistent memory (for example, RAM, volatile memory). • Controls are in place to ensure that memory maintains a non-persistent state. • SAD is removed as soon as the business purpose is complete.
Issuers and companies that support issuing services, where there is a legitimate and documented business need to store SAD, are not required to meet this requirement. A legitimate business need is one that is necessary for the performance of the function being provided by or for the issuer. Refer to Requirement 3.3.3 for additional requirements specifically for these entities. Sensitive authentication data includes the data cited in Requirements 3.3.1.1 through 3.3.1.3.		It is not permissible to store SAD in persistent memory.
		Definitions
		The authorization process completes when a merchant receives a transaction response (for example, an approval or decline).
		Refer to Appendix G for the definition of “authorization.”

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.3.1.1 The full contents of any track are not stored upon completion of the authorization process.	Defined Approach Testing Procedures 3.3.1.1 Examine data sources to verify that the full contents of any track are not stored upon completion of the authorization process.	Purpose If full contents of any track (from the magnetic stripe on the back of a card if present, equivalent data contained on a chip, or elsewhere) is stored, malicious individuals who obtain that data can use it to reproduce payment cards and complete fraudulent transactions. Definitions Full track data is alternatively called full track, track, track 1, track 2, and magnetic-stripe data. Each track contains a number of data elements, and this requirement specifies only those that may be retained post-authorization. Examples Data sources to review to ensure that the full contents of any track are not retained upon completion of the authorization process include, but are not limited to: • Incoming transaction data. • All logs (for example, transaction, history, debugging, error). • History files. • Trace files. • Database schemas. • Contents of databases, and on-premise and cloud data stores. • Any existing memory/crash dump files.
Customized Approach Objective This requirement is not eligible for the customized approach.		
Applicability Notes In the normal course of business, the following data elements from the track may need to be retained: • Cardholder name. • Primary account number (PAN). • Expiration date. • Service code. To minimize risk, store securely only these data elements as needed for business.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.3.1.2 The card verification code is not stored upon completion of the authorization process.	Defined Approach Testing Procedures 3.3.1.2 Examine data sources, to verify that the card verification code is not stored upon completion of the authorization process.	Purpose If card verification code data is stolen, malicious individuals can execute fraudulent Internet and mail-order/telephone-order (MO/TO) transactions. Not storing this data reduces the probability of it being compromised. Examples If card verification codes are stored on paper media prior to completion of authorization, a method of erasing or covering the codes should prevent them from being read after authorization is complete. Example methods of rendering the codes unreadable include removing the code with scissors and applying a suitably opaque and un-removable marker over the code. Data sources to review to ensure that the card verification code is not retained upon completion of the authorization process include, but are not limited to: • Incoming transaction data. • All logs (for example, transaction, history, debugging, error). • History files. • Trace files. • Database schemas. • Contents of databases, and on-premise and cloud data stores. • Any existing memory/crash dump files.
Customized Approach Objective This requirement is not eligible for the customized approach.		
Applicability Notes The card verification code is the three- or four-digit number printed on the front or back of a payment card used to verify card-not-present transactions.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.3.1.3 The personal identification number (PIN) and the PIN block are not stored upon completion of the authorization process.	Defined Approach Testing Procedures 3.3.1.3 Examine data sources, to verify that PINs and PIN blocks are not stored upon completion of the authorization process.	Purpose PIN and PIN blocks should be known only to the card owner or entity that issued the card. If this data is stolen, malicious individuals can execute fraudulent PIN-based transactions (for example, in-store purchases and ATM withdrawals). Not storing this data reduces the probability of it being compromised. Examples Data sources to review to ensure that PIN and PIN blocks are not retained upon completion of the authorization process include, but are not limited to: • Incoming transaction data. • All logs (for example, transaction, history, debugging, error). • History files. • Trace files. • Database schemas. • Contents of databases, and on-premise and cloud data stores. • Any existing memory/crash dump files.
Customized Approach Objective This requirement is not eligible for the customized approach.		
Applicability Notes PIN blocks are encrypted during the natural course of transaction processes, but even if an entity encrypts the PIN block again, it is still not allowed to be stored after the completion of the authorization process.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.3.2 SAD that is stored electronically prior to completion of authorization is encrypted using strong cryptography.	Defined Approach Testing Procedures 3.3.2 Examine data stores, system configurations, and/or vendor documentation to verify that all SAD that is stored electronically prior to completion of authorization is encrypted using strong cryptography.	Purpose SAD can be used by malicious individuals to increase the probability of successfully generating counterfeit payment cards and creating fraudulent transactions. Good Practice Entities should consider encrypting SAD with a different cryptographic key than is used to encrypt PAN. Note that this does not mean that PAN present in SAD (as part of track data) would need to be separately encrypted.
Customized Approach Objective This requirement is not eligible for the customized approach. <i>(continued on next page)</i>		

Requirements and Testing Procedures		Guidance
Applicability Notes Whether SAD is permitted to be stored prior to authorization is determined by the organizations that manage compliance programs (for example, payment brands and acquirers). Contact these organizations for any additional criteria. This requirement applies to all storage of SAD, even if no PAN is present in the environment. Refer to Requirement 3.2.1 for an additional requirement that applies if SAD is stored prior to completion of authorization. Issuers and companies that support issuing services, where there is a legitimate and documented business need to store SAD, are not required to meet this requirement. A legitimate business need is one that is necessary for the performance of the function being provided by or for the issuer. Refer to Requirement 3.3.3 for requirements specifically for these entities. This requirement does not replace how PIN blocks are required to be managed, nor does it mean that a properly encrypted PIN block needs to be encrypted again. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		Definitions The authorization process is completed when a merchant receives a transaction response (for example, an approval or decline) . Refer to Appendix G for the definition of “authorization.”

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.3.3 Additional requirement for issuers and companies that support issuing services and store sensitive authentication data: Any storage of sensitive authentication data is: - Limited to that which is needed for a legitimate issuing business need and is secured. - Encrypted using strong cryptography. <i>This bullet is a best practice until its effective date; refer to Applicability Notes below for details.</i>	Defined Approach Testing Procedures 3.3.3.a Additional testing procedure for issuers and companies that support issuing services and store sensitive authentication data: Examine documented policies and interview personnel to verify there is a documented business justification for the storage of sensitive authentication data. 3.3.3.b Additional testing procedure for issuers and companies that support issuing services and store sensitive authentication data: Examine data stores and system configurations to verify that the sensitive authentication data is stored securely.	Purpose SAD can be used by malicious individuals to increase the probability of successfully generating counterfeit payment cards and creating fraudulent transactions. Good Practice Entities should consider encrypting SAD with a different cryptographic key than is used to encrypt PAN. Note that this does not mean that PAN present in SAD (as part of track data) would need to be separately encrypted.
Customized Approach Objective Sensitive authentication data is retained only as required to support issuing functions and is secured from unauthorized access. <i>(continued on next page)</i>		

Requirements and Testing Procedures		Guidance
Applicability Notes This requirement applies only to issuers and companies that support issuing services and store sensitive authentication data. Entities that issue payment cards or that perform or support issuing services will often create and control sensitive authentication data as part of the issuing function. It is allowable for companies that perform, facilitate, or support issuing services to store sensitive authentication data ONLY IF they have a legitimate business need to store such data. A legitimate issuing business need is one that is necessary for the performance of the function being provided by or for the issuer. <i>The bullet above (for encrypting stored SAD with strong cryptography) is a best practice until 31 March 2025, after which it will be required as part of Requirement 3.3.3 and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures		Guidance
3.4 Access to displays of full PAN and ability to copy PAN are restricted.		
Defined Approach Requirements 3.4.1 PAN is masked when displayed (the BIN and last four digits are the maximum number of digits to be displayed), such that only personnel with a legitimate business need can see more than the BIN and last four digits of the PAN. <i>(continued on next page)</i>	Defined Approach Testing Procedures 3.4.1.a Examine documented policies and procedures for masking the display of PANs to verify: - A list of roles that need access to more than the BIN and last four digits of the PAN (includes full PAN) is documented, together with a legitimate business need for each role to have such access. - PAN is masked when displayed such that only personnel with a legitimate business need can see more than the BIN and last four digits of the PAN. - All roles not specifically authorized to see the full PAN must only see masked PANs.	Purpose The display of full PAN on computer screens, payment card receipts, paper reports, etc. can result in this data being obtained by unauthorized individuals and used fraudulently. Ensuring that the full PAN is displayed only for those with a legitimate business need minimizes the risk of unauthorized persons gaining access to PAN data. Good Practice Applying access controls according to defined roles is one way to limit access to viewing full PAN to only those individuals with a defined business need. The masking approach should always display only the number of digits needed to perform a specific business function. For example, if only the last four digits are needed to perform a business function, PAN should be masked to only show the last four digits. As another example, if a function needs to view the bank identification number (BIN) for routing purposes, unmask only the BIN digits for that function. <i>(continued on next page)</i>
	3.4.1.b Examine system configurations to verify that full PAN is only displayed for roles with a documented business need, and that PAN is masked for all other requests.	
	3.4.1.c Examine displays of PAN (for example, on screen, on paper receipts) to verify that PANs are masked when displayed, and that only those with a legitimate business need are able to see more than the BIN and/or last four digits of the PAN.	

Requirements and Testing Procedures		Guidance
Customized Approach Objective PAN displays are restricted to the minimum number of digits necessary to meet a defined business need.		Definitions Masking is not synonymous with truncation and these terms cannot be used interchangeably. Masking refers to the concealment of certain digits during display or printing, even when the entire PAN is stored on a system. This is different from truncation, in which the truncated digits are removed and cannot be retrieved within the system. Masked PAN could be “unmasked”, but there is no “un-truncation” without recreating the PAN from another source. Refer to Appendix G for definitions of “masking” and “truncation.” Further Information For more information about masking and truncation, see PCI SSC’s FAQs on these topics.
Applicability Notes This requirement does not supersede stricter requirements in place for displays of cardholder data—for example, legal or payment brand requirements for point-of-sale (POS) receipts. This requirement relates to protection of PAN where it is displayed on screens, paper receipts, printouts, etc., and is not to be confused with Requirement 3.5.1 for protection of PAN when stored, processed, or transmitted.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.4.2 When using remote-access technologies, technical controls prevent copy and/or relocation of PAN for all personnel, except for those with documented, explicit authorization and a legitimate, defined business need.	Defined Approach Testing Procedures 3.4.2.a Examine documented policies and procedures and documented evidence for technical controls that prevent copy and/or relocation of PAN when using remote-access technologies onto local hard drives or removable electronic media to verify the following: • Technical controls prevent all personnel not specifically authorized from copying and/or relocating PAN. • A list of personnel with permission to copy and/or relocate PAN is maintained, together with the documented, explicit authorization and legitimate, defined business need.	Purpose Relocation of PAN to unauthorized storage devices is a common way for this data to be obtained and used fraudulently. Methods to ensure that only those with explicit authorization and a legitimate business reason can copy or relocate PAN minimizes the risk of unauthorized persons gaining access to PAN. Good Practice Copying and relocation of PAN should only be done to storage devices that are permissible and authorized for that individual. Definitions A virtual desktop is an example of a remote-access technology. Such remote access technologies often include tools to disable copy and/or relocation functionality. Storage devices include, but are not limited to, local hard drives, virtual drives, removable electronic media, network drives, and cloud storage. Further Information Vendor documentation for the remote-access technology in use will provide information about the system settings needed to implement this requirement.
Customized Approach Objective PAN cannot be copied or relocated by unauthorized personnel using remote-access technologies.		
Applicability Notes Storing or relocating PAN onto local hard drives, removable electronic media, and other storage devices brings these devices into scope for PCI DSS. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>	3.4.2.b Examine configurations for remote-access technologies to verify that technical controls to prevent copy and/or relocation of PAN for all personnel, unless explicitly authorized. 3.4.2.c Observe processes and interview personnel to verify that only personnel with documented, explicit authorization and a legitimate, defined business need have permission to copy and/or relocate PAN when using remote-access technologies.	

Requirements and Testing Procedures		Guidance
3.5 Primary account number (PAN) is secured wherever it is stored.		
Defined Approach Requirements 3.5.1 PAN is rendered unreadable anywhere it is stored by using any of the following approaches: - One-way hashes based on strong cryptography of the entire PAN. - Truncation (hashing cannot be used to replace the truncated segment of PAN). - If hashed and truncated versions of the same PAN, or different truncation formats of the same PAN, are present in an environment, additional controls are in place such that the different versions cannot be correlated to reconstruct the original PAN. - Index tokens. - Strong cryptography with associated key-management processes and procedures.	Defined Approach Testing Procedures 3.5.1.a Examine documentation about the system used to render PAN unreadable, including the vendor, type of system/process, and the encryption algorithms (if applicable) to verify that the PAN is rendered unreadable using any of the methods specified in this requirement. 3.5.1.b Examine data repositories and audit logs, including payment application logs, to verify the PAN is rendered unreadable using any of the methods specified in this requirement. 3.5.1.c If hashed and truncated versions of the same PAN are present in the environment, examine implemented controls to verify that the hashed and truncated versions cannot be correlated to reconstruct the original PAN.	Purpose Rendering stored PAN unreadable is a defense in depth control designed to protect the data if an unauthorized individual gains access to stored data by taking advantage of a vulnerability or misconfiguration of an entity's primary access control. Good Practice It is a relatively trivial effort for a malicious individual to reconstruct original PAN data if they have access to both the truncated and hashed versions of a PAN. Controls that prevent the correlation of this data will help ensure that the original PAN remains unreadable. Implementing keyed cryptographic hashes with associated key management processes and procedures in accordance with Requirement 3.5.1.1 is a valid additional control to prevent correlation. Further Information For information about truncation formats and truncation in general, see PCI SSC's FAQs on the topic. Sources for information about index tokens include: - PCI SSC's Tokenization Product Security Guidelines (https://www.pcisecuritystandards.org/documents/Tokenization_Product_Security_Guidelines.pdf) - ANSI X9.119-2-2017: Retail Financial Services - Requirements For Protection Of Sensitive Payment Card Data - Part 2: Implementing Post-Authorization Tokenization Systems
Customized Approach Objective Cleartext PAN cannot be read from storage media.		
Applicability Notes This requirement applies to PANs stored in primary storage (databases, or flat files such as text files spreadsheets) as well as non-primary storage (backup, audit logs, exception, or troubleshooting logs). This requirement does not preclude the use of temporary files containing cleartext PAN while encrypting and decrypting PAN.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
3.5.1.1 Hashes used to render PAN unreadable (per the first bullet of Requirement 3.5.1) are keyed cryptographic hashes of the entire PAN, with associated key-management processes and procedures in accordance with Requirements 3.6 and 3.7.	3.5.1.1.a Examine documentation about the hashing method used to render PAN unreadable, including the vendor, type of system/process, and the encryption algorithms (as applicable) to verify that the hashing method results in keyed cryptographic hashes of the entire PAN, with associated key management processes and procedures.	Rendering stored PAN unreadable is a defense in depth control designed to protect the data if an unauthorized individual gains access to stored data by taking advantage of a vulnerability or misconfiguration of an entity's primary access control.
Customized Approach Objective	3.5.1.1.b Examine documentation about the key management procedures and processes associated with the keyed cryptographic hashes to verify keys are managed in accordance with Requirements 3.6 and 3.7.	A hashing function that incorporates a randomly generated secret key provides brute force attack resistance and secret authentication integrity.
	3.5.1.1.c Examine data repositories to verify the PAN is rendered unreadable.	Definitions
	3.5.1.1.d Examine audit logs, including payment application logs, to verify the PAN is rendered unreadable.	Refer to Appendix G for the definition of “keyed cryptographic hash” and for information about appropriate keyed cryptographic hashing algorithms and additional resources.
Applicability Notes		Examples
All Applicability Notes for Requirement 3.5.1 also apply to this requirement. (continued on next page)		Systems which only have access to one hash value at a time and which store no other account data on the same system as the hash, are not required to meet key-management processes and procedures (Requirements 3.6 and 3.7). Examples of such systems include transaction-originating devices that generate a hash of the PAN for use in a backend system, such as pay-at-gate transit turnstiles. However, in such an implementation, the backend system will have access to more than one hash value at a time, and therefore is required to meet key-management processes and procedures at Requirements 3.6 and 3.7.

Requirements and Testing Procedures	Guidance
<i>(continued)</i> Key-management processes and procedures (Requirements 3.6 and 3.7) do not apply to system components used to generate individual keyed hashes of a PAN for comparison to another system if: - The system components only have access to one hash value at a time (hash values are not stored on the system) AND - There is no other account data stored on the same system as the hashes. <i>This requirement is considered a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment. This requirement will replace the bullet in Requirement 3.5.1 for one-way hashes once its effective date is reached.</i>	

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.5.1.2 If disk-level or partition-level encryption (rather than file-, column-, or field-level database encryption) is used to render PAN unreadable, it is implemented only as follows: - On removable electronic media OR - If used for non-removable electronic media, PAN is also rendered unreadable via another mechanism that meets Requirement 3.5.1.	Defined Approach Testing Procedures 3.5.1.2.a Examine encryption processes to verify that, if disk-level or partition-level encryption is used to render PAN unreadable, it is implemented only as follows: - On removable electronic media, OR - If used for non-removable electronic media, examine encryption processes used to verify that PAN is also rendered unreadable via another method that meets Requirement 3.5.1. 3.5.1.2.b Examine configurations and/or vendor documentation and observe encryption processes to verify the system is configured according to vendor documentation the result is that the disk or the partition is rendered unreadable.	Purpose Disk-level and partition-level encryption typically encrypts the entire disk or partition using the same key, with all data automatically decrypted when the system runs or when an authorized user requests it. For this reason, disk-level encryption is not appropriate to protect stored PAN on computers, laptops, servers, storage arrays, or any other system that provides transparent decryption upon user authentication. Further Information Where available, following vendors' hardening and industry best practice guidelines can assist in securing PAN on these devices.
Customized Approach Objective Encrypted PAN is only decrypted when there is a legitimate business need to access that PAN. <i>(continued on next page)</i>		

Requirements and Testing Procedures	Guidance
Applicability Notes <i>(continued)</i> This requirement applies to any encryption method that provides clear-text PAN automatically when a system runs, even though an authorized user has not specifically requested that data. While disk or partition encryption may still be present on these types of devices, it cannot be the only mechanism used to protect PAN stored on those systems. Any stored PAN must also be rendered unreadable per Requirement 3.5.1—for example, through truncation or a data-level encryption mechanism. Full disk encryption helps to protect data in the event of physical loss of a disk and therefore its use is appropriate only for removable electronic media storage devices. Media that is part of a data center architecture (for example, hot-swappable drives, bulk tape-backups) is considered non-removable electronic media to which Requirement 3.5.1 applies. Disk or partition encryption implementations must also meet all other PCI DSS encryption and key-management requirements. For issuers and companies that support issuing services: This requirement does not apply to PANs being accessed for real-time transaction processing. However, it does apply to PANs stored for other purposes. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>	

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.5.1.3 If disk-level or partition-level encryption is used (rather than file-, column-, or field-level database encryption) to render PAN unreadable, it is managed as follows: - Logical access is managed separately and independently of native operating system authentication and access control mechanisms. - Decryption keys are not associated with user accounts. - Authentication factors (passwords, passphrases, or cryptographic keys) that allow access to unencrypted data are stored securely.	Defined Approach Testing Procedures 3.5.1.3.a If disk-level or partition-level encryption is used to render PAN unreadable, examine the system configuration and observe the authentication process to verify that logical access is implemented in accordance with all elements specified in this requirement. 3.5.1.3.b Examine files containing authentication factors (passwords, passphrases, or cryptographic keys) and interview personnel to verify that authentication factors that allow access to unencrypted data are stored securely and are independent from the native operating system's authentication and access control methods.	Purpose Disk-level encryption typically encrypts the entire disk or partition using the same key, with all data automatically decrypted when the system runs or when an authorized user requests it. Many disk-encryption solutions intercept operating system read/write operations and perform the appropriate cryptographic transformations without any special action by the user other than supplying a password or passphrase at system start-up or at the beginning of a session. This provides no protection from a malicious individual that has already managed to gain access to a valid user account. Good Practice Full disk encryption helps to protect data in the event of physical loss of a disk and therefore its use is best limited only to removable electronic media storage devices.
Customized Approach Objective Disk encryption implementations are configured to require independent authentication and logical access controls for decryption.		
Applicability Notes Disk or partition encryption implementations must also meet all other PCI DSS encryption and key-management requirements.		

Requirements and Testing Procedures		Guidance
3.6 Cryptographic keys used to protect stored account data are secured.		
Defined Approach Requirements 3.6.1 Procedures are defined and implemented to protect cryptographic keys used to protect stored account data against disclosure and misuse that include: • Access to keys is restricted to the fewest number of custodians necessary. • Key-encrypting keys are at least as strong as the data-encrypting keys they protect. • Key-encrypting keys are stored separately from data-encrypting keys. • Keys are stored securely in the fewest possible locations and forms.	Defined Approach Testing Procedures 3.6.1 Examine documented key-management policies and procedures to verify that processes to protect cryptographic keys used to protect stored account data against disclosure and misuse are defined to include all elements specified in this requirement.	Purpose Cryptographic keys must be strongly protected because those who obtain access will be able to decrypt data. Good Practice Having a centralized key management system based on industry standards is recommended for managing cryptographic keys. Further Information The entity's key management procedures will benefit through alignment with industry requirements, Sources for information on cryptographic key management life cycles include: • <i>ISO 11568-1 Banking — Key management (retail) — Part 1: Principles</i> (specifically Chapter 10 and the referenced Parts 2 & 4) • <i>NIST SP 800-57 Part 1 Revision 5— Recommendation for Key Management, Part 1: General.</i>
Customized Approach Objective Processes that protect cryptographic keys used to protect stored account data against disclosure and misuse are defined and implemented.		
Applicability Notes This requirement applies to keys used to protect stored account data and to key-encrypting keys used to protect data-encrypting keys. The requirement to protect keys used to protect stored account data from disclosure and misuse applies to both data-encrypting keys and key-encrypting keys. Because one key-encrypting key may grant access to many data-encrypting keys, the key-encrypting keys require strong protection measures.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Maintaining current documentation of the cryptographic architecture enables an entity to understand the algorithms, protocols, and cryptographic keys used to protect stored account data, as well as the devices that generate, use, and protect the keys. This allows an entity to keep pace with evolving threats to its architecture and plan for updates as the assurance level provided by different algorithms and key strengths changes. Maintaining such documentation also allows an entity to detect lost or missing keys or key-management devices and identify unauthorized additions to its cryptographic architecture. The use of the same cryptographic keys in both production and test environments introduces a risk of exposing the key if the test environment is not at the same security level as the production environment. Good Practice Having an automated reporting mechanism can assist with maintenance of the cryptographic attributes.
3.6.1.1 Additional requirement for service providers only: A documented description of the cryptographic architecture is maintained that includes: - Details of all algorithms, protocols, and keys used for the protection of stored account data, including key strength and expiry date. - Preventing the use of the same cryptographic keys in production and test environments. <i>This bullet is a best practice until its effective date; refer to Applicability Notes below for details.</i> - Description of the key usage for each key. - Inventory of any hardware security modules (HSMs), key management systems (KMS), and other secure cryptographic devices (SCDs) used for key management, including type and location of devices, to support meeting Requirement 12.3.4.	3.6.1.1 Additional testing procedure for service provider assessments only: Interview responsible personnel and examine documentation to verify that a document exists to describe the cryptographic architecture that includes all elements specified in this requirement.	
Customized Approach Objective Accurate details of the cryptographic architecture are maintained and available. <i>(continued on next page)</i>		

Requirements and Testing Procedures		Guidance
Applicability Notes This requirement applies only when the entity being assessed is a service provider. In cloud HSM implementations, responsibility for the cryptographic architecture according to this Requirement will be shared between the cloud provider and the cloud customer. <i>The bullet above (for including, in the cryptographic architecture, that the use of the same cryptographic keys in production and test is prevented) is a best practice until 31 March 2025, after which it will be required as part of Requirement 3.6.1.1 and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Storing cryptographic keys securely prevents unauthorized or unnecessary access that could result in the exposure of stored account data. Storing keys separately means they are stored such that if the location of one key is compromised, the second key is not also compromised. Good Practice Where data-encrypting keys are stored in an HSM, the HSM interaction channel should be protected to prevent interception of encryption or decryption operations.
3.6.1.2 Secret and private keys used to protect stored account data are stored in one (or more) of the following forms at all times: - Encrypted with a key-encrypting key that is at least as strong as the data-encrypting key, and that is stored separately from the data-encrypting key. - Within a secure cryptographic device (SCD), such as a hardware security module (HSM) or PTS-approved point-of-interaction device. - As at least two full-length key components or key shares, in accordance with an industry-accepted method.	3.6.1.2.a Examine documented procedures to verify it is defined that cryptographic keys used to encrypt/decrypt stored account data must exist only in one (or more) of the forms specified in this requirement.	
	3.6.1.2.b Examine system configurations and key storage locations to verify that cryptographic keys used to encrypt/decrypt stored account data exist in one (or more) of the forms specified in this requirement. 3.6.1.2.c Wherever key-encrypting keys are used, examine system configurations and key storage locations to verify: - Key-encrypting keys are at least as strong as the data-encrypting keys they protect. - Key-encrypting keys are stored separately from data-encrypting keys.	
Customized Approach Objective Secret and private keys are stored in a secure form that prevents unauthorized retrieval or access. <i>(continued on next page)</i>		

Requirements and Testing Procedures		Guidance
Applicability Notes It is not required that public keys be stored in one of these forms. Cryptographic keys stored as part of a key management system (KMS) that employs SCDs are acceptable. A cryptographic key that is split into two parts does not meet this requirement. Secret or private keys stored as key components or key shares must be generated via one of the following: - Using an approved random number generator and within an SCD, OR - According to ISO 19592 or equivalent industry standard for generation of secret key shares.		
Defined Approach Requirements 3.6.1.3 Access to cleartext cryptographic key components is restricted to the fewest number of custodians necessary.	Defined Approach Testing Procedures 3.6.1.3 Examine user access lists to verify that access to cleartext cryptographic key components is restricted to the fewest number of custodians necessary.	Purpose Restricting the number of people who have access to cleartext cryptographic key components reduces the risk of stored account data being retrieved or rendered visible by unauthorized parties.
Customized Approach Objective Access to cleartext cryptographic key components is restricted to necessary personnel.		Good Practice Only personnel with defined key custodian responsibilities (creating, altering, rotating, distributing, or otherwise maintaining encryption keys) should be granted access to key components. Ideally this will be a very small number of people.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.6.1.4 Cryptographic keys are stored in the fewest possible locations.	Defined Approach Testing Procedures 3.6.1.4 Examine key storage locations and observe processes to verify that keys are stored in the fewest possible locations.	Purpose Storing any cryptographic keys in the fewest locations helps an organization track and monitor all key locations and minimizes the potential for keys to be exposed to unauthorized parties.
Customized Approach Objective Cryptographic keys are retained only where necessary.		

Requirements and Testing Procedures		Guidance
3.7 Where cryptography is used to protect stored account data, key management processes and procedures covering all aspects of the key lifecycle are defined and implemented.		
Defined Approach Requirements 3.7.1 Key-management policies and procedures are implemented to include generation of strong cryptographic keys used to protect stored account data.	Defined Approach Testing Procedures 3.7.1.a Examine the documented key-management policies and procedures for keys used for protection of stored account data to verify that they define generation of strong cryptographic keys. 3.7.1.b Observe the method for generating keys to verify that strong keys are generated.	Purpose Use of strong cryptographic keys significantly increases the level of security of encrypted account data. Further Information See the sources referenced at Cryptographic Key Generation in Appendix G .
Customized Approach Objective Strong cryptographic keys are generated.		
Defined Approach Requirements 3.7.2 Key-management policies and procedures are implemented to include secure distribution of cryptographic keys used to protect stored account data.	Defined Approach Testing Procedures 3.7.2.a Examine the documented key-management policies and procedures for keys used for protection of stored account data to verify that they define secure distribution of cryptographic keys. 3.7.2.b Observe the method for distributing keys to verify that keys are distributed securely.	Purpose Secure distribution or conveyance of secret or private cryptographic keys means that keys are distributed only to authorized custodians, as identified in Requirement 3.6.1.2, and are never distributed insecurely.
Customized Approach Objective Cryptographic keys are secured during distribution.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.7.3 Key-management policies and procedures are implemented to include secure storage of cryptographic keys used to protect stored account data.	Defined Approach Testing Procedures 3.7.3.a Examine the documented key-management policies and procedures for keys used for protection of stored account data to verify that they define secure storage of cryptographic keys. 3.7.3.b Observe the method for storing keys to verify that keys are stored securely.	Purpose Storing keys without proper protection could provide access to attackers, resulting in the decryption and exposure of account data. Good Practice Data encryption keys can be protected by encrypting them with a key-encrypting key. Keys can be stored in a Hardware Security Module (HSM). Secret or private keys that can decrypt data should never be present in source code.
Customized Approach Objective Cryptographic keys are secured when stored.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.7.4 Key management policies and procedures are implemented for cryptographic key changes for keys that have reached the end of their cryptoperiod, as defined by the associated application vendor or key owner, and based on industry best practices and guidelines, including the following: • A defined cryptoperiod for each key type in use. • A process for key changes at the end of the defined cryptoperiod.	Defined Approach Testing Procedures 3.7.4.a Examine the documented key-management policies and procedures for keys used for protection of stored account data to verify that they define changes to cryptographic keys that have reached the end of their cryptoperiod and include all elements specified in this requirement. 3.7.4.b Interview personnel, examine documentation, and observe key storage locations to verify that keys are changed at the end of the defined cryptoperiod(s).	Purpose Changing encryption keys when they reach the end of their cryptoperiod is imperative to minimize the risk of someone obtaining the encryption keys and using them to decrypt data. Definitions A cryptoperiod is the time span during which a cryptographic key can be used for its defined purpose. Cryptoperiods are often defined in terms of the period for which the key is active and/or the amount of ciphertext that has been produced by the key. Considerations for defining the cryptoperiod include, but are not limited to, the strength of the underlying algorithm, size or length of the key, risk of key compromise, and the sensitivity of the data being encrypted. Further Information <i>NIST SP 800-57 Part 1, Revision 5, Section 5.3 Cryptoperiods</i> – provides guidance for establishing the time span during which a specific key is authorized for use by legitimate entities, or the keys for a given system will remain in effect. See Table 1 of <i>SP 800-57 Part 1</i> for suggested cryptoperiods for different key types.
Customized Approach Objective Cryptographic keys are not used beyond their defined cryptoperiod.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.7.5 Key management policies procedures are implemented to include the retirement, replacement, or destruction of keys used to protect stored account data, as deemed necessary when: - The key has reached the end of its defined cryptoperiod. - The integrity of the key has been weakened, including when personnel with knowledge of a cleartext key component leaves the company, or the role for which the key component was known. - The key is suspected of or known to be compromised. Retired or replaced keys are not used for encryption operations.	Defined Approach Testing Procedures 3.7.5.a Examine the documented key-management policies and procedures for keys used for protection of stored account data and verify that they define retirement, replacement, or destruction of keys in accordance with all elements specified in this requirement. 3.7.5.b Interview personnel to verify that processes are implemented in accordance with all elements specified in this requirement.	Purpose Keys that are no longer required, keys with weakened integrity, and keys that are known or suspected to be compromised, should be archived, revoked, and/or destroyed to ensure that the keys can no longer be used. If such keys need to be kept (for example, to support archived encrypted data), they should be strongly protected. Good Practice Archived cryptographic keys should be used only for decryption/verification purposes. The encryption solution should provide for and facilitate a process to replace keys that are due for replacement or that are known to be, or suspected of being, compromised. In addition, any keys that are known to be, or suspected of being, compromised should be managed in accordance with the entity's incident response plan per Requirement 12.10.1. Further Information Industry best practices for archiving retired keys are outlined in <i>NIST SP 800-57 Part 1, Revision 5, Section 8.3.1</i>, and includes maintaining the archive with a trusted third party and storing archived key information separately from operational data.
Customized Approach Objective Keys are removed from active use when it is suspected or known that the integrity of the key is weakened.		
Applicability Notes If retired or replaced cryptographic keys need to be retained, these keys must be securely archived (for example, by using a key-encryption key).		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
3.7.6 Where manual cleartext cryptographic key-management operations are performed by personnel, key-management policies and procedures are implemented, including managing these operations using split knowledge and dual control.	3.7.6.a Examine the documented key-management policies and procedures for keys used for protection of stored account data and verify that they define using split knowledge and dual control.	Split knowledge and dual control of keys are used to eliminate the possibility of a single person having access to the whole key and therefore being able to gain unauthorized access to the data.
Customized Approach Objective	3.7.6.b Interview personnel and/or observe processes to verify that manual cleartext keys are managed with split knowledge and dual control.	Definitions
Cleartext secret or private keys cannot be known by anyone. Operations involving cleartext keys cannot be carried out by a single person.		Split knowledge is a method in which two or more people separately have key components, where each person knows only their own key component, and the individual key components convey no knowledge of other components or of the original cryptographic key. Dual control requires two or more people to authenticate the use of a cryptographic key or perform a key-management function. No single person can access or use the authentication factor (for example, the password, PIN, or key) of another.
Applicability Notes		Good Practice
This control is applicable for manual key-management operations. A cryptographic key that is simply split into two parts does not meet this requirement. Secret or private keys stored as key components or key shares must be generated via one of the following: - Using an approved random number generator and within a secure cryptographic device (SCD), such as a hardware security module (HSM) or PTS-approved point-of-interaction device, OR - According to ISO 19592 or equivalent industry standard for generation of secret key shares.		Where key components or key shares are used, procedures should ensure that no single custodian ever has access to sufficient key components or shares to reconstruct the cryptographic key. For example, in an m-of-n scheme (for example, Shamir), where only two of any three components are required to reconstruct the cryptographic key, a custodian must not have current or prior knowledge of more than one component. If a custodian was previously assigned component A, which was then reassigned, the custodian should not then be assigned component B or C, as this would give the custodian knowledge of two components and the ability to recreate the key. <i>(continued on next page)</i>

Requirements and Testing Procedures		Guidance
3.7.6 (continued)		Examples Key-management operations that might be performed manually include, but are not limited to, key generation, transmission, loading, storage, and destruction. Further Information Industry standards for managing key components include: • <i>NIST SP 800-57 Part 2, Revision 1 -- Recommendation for Key Management: Part 2 – Best Practices for Key Management Organizations [4.6 Keying Material Distribution]</i> • <i>ISO 11568-2 Banking — Key management (retail) — Part 2: Symmetric ciphers, their key management and life cycle [4.7.2.3 Key components and 4.9.3 Key components]</i> • <i>European Payments Council EPC342-08 Guidelines on Cryptographic Algorithms Usage and Key Management [especially 4.1.4 Key installation].</i>
Defined Approach Requirements 3.7.7 Key management policies and procedures are implemented to include the prevention of unauthorized substitution of cryptographic keys. Customized Approach Objective Cryptographic keys cannot be substituted by unauthorized personnel.	Defined Approach Testing Procedures 3.7.7.a Examine the documented key-management policies and procedures for keys used for protection of stored account data and verify that they define prevention of unauthorized substitution of cryptographic keys. 3.7.7.b Interview personnel and/or observe processes to verify that unauthorized substitution of keys is prevented.	Purpose If an attacker is able to substitute an entity's key with a key the attacker knows, the attacker will be able to decrypt all data encrypted with that key. Good Practice The encryption solution should not allow for or accept substitution of keys from unauthorized sources or unexpected processes. Controls should include ensuring that individuals with access to key components or shares do not have access to other components or shares that form the necessary threshold to derive the key.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.7.8 Key management policies and procedures are implemented to include that cryptographic key custodians formally acknowledge (in writing or electronically) that they understand and accept their key-custodian responsibilities.	Defined Approach Testing Procedures 3.7.8.a Examine the documented key-management policies and procedures for keys used for protection of stored account data and verify that they define acknowledgments for key custodians in accordance with all elements specified in this requirement. 3.7.8.b Examine documentation or other evidence showing that key custodians have provided acknowledgments in accordance with all elements specified in this requirement.	Purpose This process will help ensure individuals that act as key custodians commit to the key-custodian role and understand and accept the responsibilities. An annual reaffirmation can help remind key custodians of their responsibilities. Further Information Industry guidance for key custodians and their roles and responsibilities includes: • <i>NIST SP 800-130 A Framework for Designing Cryptographic Key Management Systems</i> [5. Roles and Responsibilities (especially) for Key Custodians] • <i>ISO 11568-1 Banking -- Key management (retail) -- Part 1: Principles</i> [5 Principles of key management (especially b)]
Customized Approach Objective Key custodians are knowledgeable about their responsibilities in relation to cryptographic operations and can access assistance and guidance when required.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 3.7.9 Additional requirement for service providers only: Where a service provider shares cryptographic keys with its customers for transmission or storage of account data, guidance on secure transmission, storage and updating of such keys is documented and distributed to the service provider's customers.	Defined Approach Testing Procedures 3.7.9 Additional testing procedure for service provider assessments only: If the service provider shares cryptographic keys with its customers for transmission or storage of account data, examine the documentation that the service provider provides to its customers to verify it includes guidance on how to securely transmit, store, and update customers' keys in accordance with all elements specified in Requirements 3.7.1 through 3.7.8 above.	Purpose Providing guidance to customers on how to securely transmit, store, and update cryptographic keys can help prevent keys from being mismanaged or disclosed to unauthorized entities. Further Information Numerous industry standards for key management are cited above in the Guidance for Requirements 3.7.1-3.7.8.
Customized Approach Objective Customers are provided with appropriate key management guidance whenever they receive shared cryptographic keys.		
Applicability Notes This requirement applies only when the entity being assessed is a service provider.		

Requirement 4: Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks

Sections

- 4.1** Processes and mechanisms for protecting cardholder data with strong cryptography during transmission over open, public networks are defined and understood.
- 4.2** PAN is protected with strong cryptography during transmission

Overview

The use of strong cryptography provides greater assurance in preserving data confidentiality, integrity, and non-repudiation.

To protect against compromise, PAN must be encrypted during transmission over networks that are easily accessed by malicious individuals, including untrusted and public networks. Misconfigured wireless networks and vulnerabilities in legacy encryption and authentication protocols continue to be targeted by malicious individuals aiming to exploit these vulnerabilities to gain privileged access to cardholder data environments (CDE). Any transmissions of cardholder data over an entity's internal network(s) will naturally bring that network into scope for PCI DSS since that network stores, processes, or transmits cardholder data. Any such networks must be evaluated and assessed against applicable PCI DSS requirements.

Requirement 4 applies to transmissions of PAN unless specifically called out in an individual requirement.

PAN transmissions can be protected by encrypting the data before it is transmitted, or by encrypting the session over which the data is transmitted, or both. While it is not required that strong cryptography be applied at both the data level and the session level, it is recommended.

Refer to [Appendix G](#) for definitions of "strong cryptography" and other PCI DSS terms.

Requirements and Testing Procedures		Guidance
4.1 Processes and mechanisms for protecting cardholder data with strong cryptography during transmission over open, public networks are defined and understood.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
4.1.1 All security policies and operational procedures that are identified in Requirement 4 are: • Documented. • Kept up to date. • In use. • Known to all affected parties.	4.1.1 Examine documentation and interview personnel to verify that security policies and operational procedures identified in Requirement 4 are managed in accordance with all elements specified in this requirement.	Requirement 4.1.1 is about effectively managing and maintaining the various policies and procedures specified throughout Requirement 4. While it is important to define the specific policies or procedures called out in Requirement 4, it is equally important to ensure they are properly documented, maintained, and disseminated.
Customized Approach Objective		Good Practice It is important to update policies and procedures as needed to address changes in processes, technologies, and business objectives. For this reason, consider updating these documents as soon as possible after a change occurs and not only on a periodic cycle. Definitions Security policies define the entity's security objectives and principles. Operational procedures describe how to perform activities, and define the controls, methods, and processes that are followed to achieve the desired result in a consistent manner and in accordance with policy objectives. Policies and procedures, including updates, are actively communicated to all affected personnel, and are supported by operating procedures describing how to perform activities.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose If roles and responsibilities are not formally assigned, personnel may not be aware of their day-to-day responsibilities and critical activities may not occur. Good Practice Roles and responsibilities may be documented within policies and procedures or maintained within separate documents. As part of communicating roles and responsibilities, entities can consider having personnel acknowledge their acceptance and understanding of their assigned roles and responsibilities. Examples A method to document roles and responsibilities is a responsibility assignment matrix that includes who is responsible, accountable, consulted, and informed (also called a RACI matrix).
4.1.2 Roles and responsibilities for performing activities in Requirement 4 are documented, assigned, and understood.	4.1.2.a Examine documentation to verify that descriptions of roles and responsibilities for performing activities in Requirement 4 are documented and assigned.	
Customized Approach Objective Day-to-day responsibilities for performing all the activities in Requirement 4 are allocated. Personnel are accountable for successful, continuous operation of these requirements.	4.1.2.b Interview personnel with responsibility for performing activities in Requirement 4 to verify that roles and responsibilities are assigned as documented and are understood.	

Requirements and Testing Procedures		Guidance
4.2 PAN is protected with strong cryptography during transmission.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
4.2.1 Strong cryptography and security protocols are implemented as follows to safeguard PAN during transmission over open, public networks: - Only trusted keys and certificates are accepted. - Certificates used to safeguard PAN during transmission over open, public networks are confirmed as valid and are not expired or revoked. <i>This bullet is a best practice until its effective date; refer to applicability notes below for details.</i> - The protocol in use supports only secure versions or configurations and does not support fallback to, or use of insecure versions, algorithms, key sizes, or implementations. - The encryption strength is appropriate for the encryption methodology in use.	4.2.1.a Examine documented policies and procedures and interview personnel to verify processes are defined to include all elements specified in this requirement.	Sensitive information must be encrypted during transmission over public networks because it is easy and common for a malicious individual to intercept and/or divert data while in transit. Good Practice The network and data-flow diagrams defined in Requirement 1 are useful resources for identifying all connection points where account data is transmitted or received over open, public networks. While not required, it is considered a good practice for entities to also encrypt PAN over their internal networks, and for entities to establish any new network implementations with encrypted communications. PAN transmissions can be protected by encrypting the data before it is transmitted, or by encrypting the session over which the data is transmitted, or both. While it is not required that strong cryptography be applied at both the data level and the session level, it is strongly recommended. If encrypted at the data level, the cryptographic keys used for protecting the data can be managed in accordance with Requirements 3.6 and 3.7. If the data is encrypted at the session level, designated key custodians should be assigned responsibility for managing transmission keys and certificates. <i>(continued on next page)</i>
	4.2.1.b Examine system configurations to verify that strong cryptography and security protocols are implemented in accordance with all elements specified in this requirement.	
	4.2.1.c Examine cardholder data transmissions to verify that all PAN is encrypted with strong cryptography when it is transmitted over open, public networks.	
	4.2.1.d Examine system configurations to verify that keys and/or certificates that cannot be verified as trusted are rejected.	
Customized Approach Objective		
Cleartext PAN cannot be read or intercepted from any transmissions over open, public networks.		

Requirements and Testing Procedures		Guidance
Applicability Notes A self-signed certificate may also be acceptable if the certificate is issued by an internal CA within the organization, the certificate's author is confirmed, and the certificate is verified—for example, via hash or signature—and has not expired. <i>The bullet above (for confirming that certificates used to safeguard PAN during transmission over open, public networks are valid and are not expired or revoked) is a best practice until 31 March 2025, after which it will be required as part of Requirement 4.2.1 and must be fully considered during a PCI DSS assessment.</i>		Some protocol implementations (such as SSL, SSH v1.0, and early TLS) have known vulnerabilities that an attacker can use to gain access to the cleartext data. It is critical that entities maintain awareness of industry-defined deprecation dates for the cipher suites they are using and are prepared to migrate to newer versions or protocols when older ones are no longer deemed secure. Verifying that certificates are trusted helps ensure the integrity of the secure connection. To be considered trusted, a certificate should be issued from a trusted source, such as a trusted certificate authority (CA), and not be expired. Up-to-date Certificate Revocation Lists (CRLs) or Online Certificate Status Protocol (OCSP) can be used to validate certificates. Techniques to validate certificates may include certificate and public key pinning, where the trusted certificate or a public key is pinned either during development or upon its first use. Entities can also confirm with developers or review source code to ensure that clients and servers reject connections if the certificate is bad. For browser-based TLS certificates, certificate trust can often be verified by clicking on the lock icon that appears next to the address bar. <i>(continued on next page)</i>

Requirements and Testing Procedures	Guidance
4.2.1 (continued)	Examples Open, public networks include, but are not limited to: • The Internet and • Wireless technologies, including Wi-Fi, Bluetooth, cellular technologies, and satellite communications. Further Information Vendor recommendations and industry best practices can be consulted for information about the proper encryption strength specific to the encryption methodology in use. For more information about strong cryptography and secure protocols, see industry standards and best practices such as <i>NIST SP 800-52</i> and <i>SP 800-57</i>. For more information about trusted keys and certificates, see <i>NIST Cybersecurity Practice Guide Special Publication 1800-16, Securing Web Transactions: Transport Layer Security (TLS) Server Certificate Management</i>.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 4.2.1.1 An inventory of the entity's trusted keys and certificates used to protect PAN during transmission is maintained.	Defined Approach Testing Procedures 4.2.1.1.a Examine documented policies and procedures to verify processes are defined for the entity to maintain an inventory of its trusted keys and certificates. 4.2.1.1.b Examine the inventory of trusted keys and certificates to verify it is kept up to date.	Purpose The inventory of trusted keys helps the entity keep track of the algorithms, protocols, key strength, key custodians, and key expiry dates. This enables the entity to respond quickly to vulnerabilities discovered in encryption software, certificates, and cryptographic algorithms. Good Practice For certificates, the inventory should include the issuing CA and certification expiration date.
Customized Approach Objective All keys and certificates used to protect PAN during transmission are identified and confirmed as trusted.		
Applicability Notes <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
4.2.1.2 Wireless networks transmitting PAN or connected to the CDE use industry best practices to implement strong cryptography for authentication and transmission.	4.2.1.2 Examine system configurations to verify that wireless networks transmitting PAN or connected to the CDE use industry best practices to implement strong cryptography for authentication and transmission.	Since wireless networks do not require physical media to connect, it is important to establish controls limiting who can connect and what transmission protocols will be used. Malicious users use free and widely available tools to eavesdrop on wireless communications. Use of strong cryptography can help limit disclosure of sensitive information across wireless networks. Wireless networks present unique risks to an organization; therefore, they must be identified and protected according to industry requirements. Strong cryptography for authentication and transmission of PAN is required to prevent malicious users from gaining access to the wireless network or utilizing wireless networks to access other internal networks or data.
Customized Approach Objective		Good Practice Wireless networks should not permit fallback or downgrade to an insecure protocol or lower encryption strength that does not meet the intent of strong cryptography. Further Information Review the vendor's specific documentation for more details on the choice of protocols, configurations, and settings related to cryptography.
Cleartext PAN cannot be read or intercepted from wireless network transmissions.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 4.2.2 PAN is secured with strong cryptography whenever it is sent via end-user messaging technologies.	Defined Approach Testing Procedures 4.2.2.a Examine documented policies and procedures to verify that processes are defined to secure PAN with strong cryptography whenever sent over end-user messaging technologies. 4.2.2.b Examine system configurations and vendor documentation to verify that PAN is secured with strong cryptography whenever it is sent via end-user messaging technologies.	Purpose End-user messaging technologies typically can be easily intercepted by packet-sniffing during delivery across internal and public networks. Good Practice The use of end-user messaging technology to send PAN should only be considered where there is a defined business need and should be controlled through the Acceptable Use Policies for end-user technologies defined by the entity according to Requirement 12.2.1. Examples E-mail, instant messaging, SMS, and chat are examples of the type of end-user messaging technology that this requirement refers to.
Customized Approach Objective Cleartext PAN cannot be read or intercepted from transmissions using end-user messaging technologies.		
Applicability Notes This requirement also applies if a customer, or other third party, requests that PAN is sent to them via end-user messaging technologies. There could be occurrences where an entity receives unsolicited cardholder data via an insecure communication channel that was not intended for transmissions of sensitive data. In this situation, the entity can choose to either include the channel in the scope of their CDE and secure it according to PCI DSS or delete the cardholder data and implement measures to prevent the channel from being used for cardholder data.		

Implement Strong Access Control Measures

Requirement 7: Restrict Access to System Components and Cardholder Data by Business Need to Know

Sections

- 7.1** Processes and mechanisms for restricting access to system components and cardholder data by business need to know are defined and understood.
- 7.2** Access to system components and data is appropriately defined and assigned.
- 7.3** Access to system components and data is managed via an access control system(s).

Overview

Unauthorized individuals may gain access to critical data or systems due to ineffective access control rules and definitions. To ensure critical data can only be accessed by authorized personnel, systems and processes must be in place to limit access based on need to know and according to job responsibilities.

“Access” or “access rights” are created by rules that provide users access to systems, applications, and data, while “privileges” allow a user to perform a specific action or function in relation to that system, application, or data. For example, a user may have access rights to specific data, but whether they can only read that data, or can also change or delete the data is determined by the user’s assigned privileges.

“Need to know” refers to providing access to only the least amount of data needed to perform a job.

“Least privileges” refers to providing only the minimum level of privileges needed to perform a job.

These requirements apply to user accounts and access for employees, contractors, consultants, and internal and external vendors and other third parties (for example, for providing support or maintenance services). Certain requirements also apply to application and system accounts used by the entity (also called “service accounts”).

These requirements do not apply to consumers (cardholders).

Refer to [Appendix G](#) for definitions of PCI DSS terms.

Requirements and Testing Procedures		Guidance
7.1 Processes and mechanisms for restricting access to system components and cardholder data by business need to know are defined and understood.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
7.1.1 All security policies and operational procedures that are identified in Requirement 7 are: • Documented. • Kept up to date. • In use. • Known to all affected parties.	7.1.1 Examine documentation and interview personnel to verify that security policies and operational procedures identified in Requirement 7 are managed in accordance with all elements specified in this requirement.	Requirement 7.1.1 is about effectively managing and maintaining the various policies and procedures specified throughout Requirement 7. While it is important to define the specific policies or procedures called out in Requirement 7, it is equally important to ensure they are properly documented, maintained, and disseminated. Good Practice It is important to update policies and procedures as needed to address changes in processes, technologies, and business objectives. For this reason, consider updating these documents as soon as possible after a change occurs and not only on a periodic cycle. Definitions Security policies define the entity's security objectives and principles. Operational procedures describe how to perform activities, and define the controls, methods, and processes that are followed to achieve the desired result in a consistent manner and in accordance with policy objectives.
Customized Approach Objective		
Expectations, controls, and oversight for meeting activities within Requirement 7 are defined and adhered to by affected personnel. All supporting activities are repeatable, consistently applied, and conform to management's intent.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose If roles and responsibilities are not formally assigned, personnel may not be aware of their day-to-day responsibilities, and critical activities may not occur. Good Practice Roles and responsibilities may be documented within policies and procedures or maintained within separate documents. As part of communicating roles and responsibilities, entities can consider having personnel acknowledge their acceptance and understanding of their assigned roles and responsibilities. Examples A method to document roles and responsibilities is a responsibility assignment matrix that includes who is responsible, accountable, consulted, and informed (also called a RACI matrix).
7.1.2 Roles and responsibilities for performing activities in Requirement 7 are documented, assigned, and understood.	7.1.2.a Examine documentation to verify that descriptions of roles and responsibilities for performing activities in Requirement 7 are documented and assigned.	
Customized Approach Objective Day-to-day responsibilities for performing all the activities in Requirement 7 are allocated. Personnel are accountable for successful, continuous operation of these requirements.	7.1.2.b Interview personnel with responsibility for performing activities in Requirement 7 to verify that roles and responsibilities are assigned as and are understood.	

Requirements and Testing Procedures		Guidance
7.2 Access to system components and data is appropriately defined and assigned.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
7.2.1 An access control model is defined and includes granting access as follows: • Appropriate access depending on the entity's business and access needs. • Access to system components and data resources that is based on users' job classification and functions. • The least privileges required (for example, user, administrator) to perform a job function.	7.2.1.a Examine documented policies and procedures and interview personnel to verify the access control model is defined in accordance with all elements specified in this requirement. 7.2.1.b Examine access control model settings and verify that access needs are appropriately defined in accordance with all elements specified in this requirement.	Defining an access control model that is appropriate for the entity's technology and access control philosophy supports a consistent and uniform way of allocating access and reduces the possibility of errors such as the granting of excessive rights. Good Practice A factor to consider when defining access needs is the separation of duties principle. This principle is intended to prevent fraud and misuse or theft of resources. For example, 1) dividing mission-critical functions and information system support functions among different individuals and/or functions, 2) establishing roles such that information system support activities are performed by different functions/individuals (for example, system management, programming, configuration management, quality assurance and testing, and network security), and 3) ensuring security personnel administering access control functions do not also administer audit functions. In environments where one individual performs multiple functions, such as administration and security operations, duties may be assigned so that no single individual has end-to-end control of a process without an independent checkpoint. For example, responsibility for configuration and responsibility for approving changes could be assigned to separate individuals. <i>(continued on next page)</i>
Customized Approach Objective		
Access requirements are established according to job functions following least-privilege and need-to-know principles.		

Requirements and Testing Procedures	Guidance
7.1.2 (continued)	Definitions Key elements of an access control model include: • Resources to be protected (the systems/devices/data to which access is needed), • Job functions that need access to the resource (for example, system administrator, call-center personnel, store clerk), and • Which activities each job function needs to perform (for example, read/write or query). Once job functions, resources, and activities per job functions are defined, individuals can be granted access accordingly. Examples Access control models that entities can consider include role-based access control (RBAC) and attribute-based access control (ABAC). The access control model used by a given entity depends on their business and access needs.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Assigning least privileges helps prevent users without sufficient knowledge about the application from incorrectly or accidentally changing application configuration or altering its security settings. Enforcing least privilege also helps to minimize the scope of damage if an unauthorized person gains access to a user ID. Good Practice Access rights are granted to a user by assignment to one or several functions. Access is assigned depending on the specific user functions and with the minimum scope required for the job. When assigning privileged access, it is important to assign individuals only the privileges they need to perform their job (the “least privileges”). For example, the database administrator or backup administrator should not be assigned the same privileges as the overall systems administrator. Once needs are defined for user functions (per PCI DSS requirement 7.2.1), it is easy to grant individuals access according to their job classification and function by using the already-created roles. Entities may wish to consider use of Privileged Access Management (PAM), which is a method to grant access to privileged accounts only when those privileges are required, immediately revoking that access once they are no longer needed.
7.2.2 Access is assigned to users, including privileged users, based on: • Job classification and function. • Least privileges necessary to perform job responsibilities.	7.2.2.a Examine policies and procedures to verify they cover assigning access to users in accordance with all elements specified in this requirement.	
	7.2.2.b Examine user access settings, including for privileged users, and interview responsible management personnel to verify that privileges assigned are in accordance with all elements specified in this requirement.	
Customized Approach Objective Access to systems and data is limited to only the access needed to perform job functions, as defined in the related access roles.	7.2.2.c Interview personnel responsible for assigning access to verify that privileged user access is assigned in accordance with all elements specified in this requirement.	

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Documented approval (for example, in writing or electronically) assures that those with access and privileges are known and authorized by management, and that their access is necessary for their job function.
7.2.3 Required privileges are approved by authorized personnel.	7.2.3.a Examine policies and procedures to verify they define processes for approval of all privileges by authorized personnel.	
Customized Approach Objective Access privileges cannot be granted to users without appropriate, documented authorization.	7.2.3.b Examine user IDs and assigned privileges, and compare with documented approvals to verify that: • Documented approval exists for the assigned privileges. • The approval was by authorized personnel. • Specified privileges match the roles assigned to the individual.	

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 7.2.4 All user accounts and related access privileges, including third-party/vendor accounts, are reviewed as follows: - At least once every six months. - To ensure user accounts and access remain appropriate based on job function. - Any inappropriate access is addressed. - Management acknowledges that access remains appropriate.	Defined Approach Testing Procedures 7.2.4.a Examine policies and procedures to verify they define processes to review all user accounts and related access privileges, including third-party/vendor accounts, in accordance with all elements specified in this requirement. 7.2.4.b Interview responsible personnel and examine documented results of periodic reviews of user accounts to verify that all the results are in accordance with all elements specified in this requirement.	Purpose Regular review of access rights helps to detect excessive access rights remaining after user job responsibilities change, system functions change, or other modifications. If excessive user rights are not revoked in due time, they may be used by malicious users for unauthorized access. This review provides another opportunity to ensure that accounts for all terminated users have been removed (if any were missed at the time of termination), as well as to ensure that any third parties that no longer need access have had their access terminated. Good Practice When a user transfers into a new role or a new department, typically the privileges and access associated with their former role are no longer required. Continued access to privileges or functions that are no longer required may introduce the risk of misuse or errors. Therefore, when responsibilities change, processes that revalidate access help to ensure user access is appropriate for the user's new responsibilities. Entities can consider implementing a regular, repeatable process for conducting reviews of access rights, and assigning "data owners" that are responsible for managing and monitoring access to data related to their job function and that also ensure user access remains current and appropriate. As an example, a direct manager could review team access monthly, while the senior manager reviews their groups' access quarterly, both making updates to access as needed. The intent of these best practices is to support and facilitate conducting the reviews at least once every 6 months.
Customized Approach Objective Account privilege assignments are verified periodically by management as correct, and nonconformities are remediated.		
Applicability Notes This requirement applies to all user accounts and related access privileges, including those used by personnel and third parties/vendors, and accounts used to access third-party cloud services. See Requirements 7.2.5 and 7.2.5.1 and 8.6.1 through 8.6.3 for controls for application and system accounts. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 7.2.5 All application and system accounts and related access privileges are assigned and managed as follows: - Based on the least privileges necessary for the operability of the system or application. - Access is limited to the systems, applications, or processes that specifically require their use.	Defined Approach Testing Procedures 7.2.5.a Examine policies and procedures to verify they define processes to manage and assign application and system accounts and related access privileges in accordance with all elements specified in this requirement. 7.2.5.b Examine privileges associated with system and application accounts and interview responsible personnel to verify that application and system accounts and related access privileges are assigned and managed in accordance with all elements specified in this requirement.	Purpose It is important to establish the appropriate access level for application or system accounts. If such accounts are compromised, malicious users will receive the same access level as that granted to the application or system. Therefore, it is important to ensure limited access is granted to system and application accounts on the same basis as to user accounts. Good Practice Entities may want to consider establishing a baseline when setting up these application and system accounts including the following as applicable to the organization: - Making sure that the account is not a member of a privileged group such as domain administrators, local administrators, or root. - Restricting which computers the account can be used on. - Restricting hours of use. - Removing any additional settings like VPN access and remote access.
Customized Approach Objective Access rights granted to application and system accounts are limited to only the access needed for the operability of that application or system.		
Applicability Notes <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Regular review of access rights helps to detect excessive access rights remaining after system functions change, or other application or system modifications occur. If excessive rights are not removed when no longer needed, they may be used by malicious users for unauthorized access.
7.2.5.1 All access by application and system accounts and related access privileges are reviewed as follows: - Periodically (at the frequency defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1). - The application/system access remains appropriate for the function being performed. - Any inappropriate access is addressed. - Management acknowledges that access remains appropriate.	7.2.5.1.a Examine policies and procedures to verify they define processes to review all application and system accounts and related access privileges in accordance with all elements specified in this requirement.	
	7.2.5.1.b Examine the entity's targeted risk analysis for the frequency of periodic reviews of application and system accounts and related access privileges to verify the risk analysis was performed in accordance with all elements specified in Requirement 12.3.1.	
	7.2.5.1.c Interview responsible personnel and examine documented results of periodic reviews of system and application accounts and related privileges to verify that the reviews occur in accordance with all elements specified in this requirement.	
Customized Approach Objective Application and system account privilege assignments are verified periodically by management as correct, and nonconformities are remediated.		
Applicability Notes <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 7.2.6 All user access to query repositories of stored cardholder data is restricted as follows: • Via applications or other programmatic methods, with access and allowed actions based on user roles and least privileges. • Only the responsible administrator(s) can directly access or query repositories of stored CHD.	Defined Approach Testing Procedures 7.2.6.a Examine policies and procedures and interview personnel to verify processes are defined for granting user access to query repositories of stored cardholder data, in accordance with all elements specified in this requirement. 7.2.6.b Examine configuration settings for querying repositories of stored cardholder data to verify they are in accordance with all elements specified in this requirement.	Purpose The misuse of query access to repositories of cardholder data has been a regular cause of data breaches. Limiting such access to administrators reduces the risk of such access being abused by unauthorized users. Definitions “Programmatic methods” means granting access through means such as database stored procedures that allow users to perform controlled actions to data in a table, rather than via direct, unfiltered access to the data repository by end users (except for the responsible administrator(s), who need direct access to the database for their administrative duties). Good Practice Typical user actions include moving, copying, and deleting data. Also consider the scope of privilege needed when granting access. For example, access can be granted to specific objects such as data elements, files, tables, indexes, views, and stored routines. Granting access to repositories of cardholder data should follow the same process as all other granted access, meaning that it is based on roles, with only the privileges assigned to each user that are needed to perform their job functions.
Customized Approach Objective Direct unfiltered (ad hoc) query access to cardholder data repositories is prohibited, unless performed by an authorized administrator.		
Applicability Notes This requirement applies to controls for user access to query repositories of stored cardholder data. See Requirements 7.2.5 and 7.2.5.1 and 8.6.1 through 8.6.3 for controls for application and system accounts.		

Requirements and Testing Procedures		Guidance
7.3 Access to system components and data is managed via an access control system(s).		
Defined Approach Requirements 7.3.1 An access control system(s) is in place that restricts access based on a user's need to know and covers all system components.	Defined Approach Testing Procedures 7.3.1 Examine vendor documentation and system settings to verify that access is managed for each system component via an access control system(s) that restricts access based on a user's need to know and covers all system components.	Purpose Without a mechanism to restrict access based on user's need to know, a user may unknowingly be granted access to cardholder data. Access control systems automate the process of restricting access and assigning privileges.
Customized Approach Objective Access rights and privileges are managed via mechanisms intended for that purpose.		
Defined Approach Requirements 7.3.2 The access control system(s) is configured to enforce permissions assigned to individuals, applications, and systems based on job classification and function.	Defined Approach Testing Procedures 7.3.2 Examine vendor documentation and system settings to verify that the access control system(s) is configured to enforce permissions assigned to individuals, applications, and systems based on job classification and function.	Purpose Restricting privileged access with an access control system reduces the opportunity for errors in the assignment of permissions to individuals, applications, and systems.
Customized Approach Objective Individual account access rights and privileges to systems, applications, and data are only inherited from group membership.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 7.3.3 The access control system(s) is set to “deny all” by default.	Defined Approach Testing Procedures 7.3.3 Examine vendor documentation and system settings to verify that the access control system(s) is set to “deny all” by default.	Purpose A default setting of “deny all” ensures no one is granted access unless a rule is established specifically granting such access. Good Practice It is important to check the default configuration of access control systems because some are set by default to “allow all,” thereby permitting access unless/until a rule is written to specifically deny it.
Customized Approach Objective Access rights and privileges are prohibited unless expressly permitted.		

Requirement 8: Identify Users and Authenticate Access to System Components

Sections

- 8.1 Processes and mechanisms for identifying users and authenticating access to system components are defined and understood.
- 8.2 User identification and related accounts for users and administrators are strictly managed throughout an account's lifecycle.
- 8.3 Strong authentication for users and administrators is established and managed.
- 8.4 Multi-factor authentication (MFA) is implemented to secure access into the CDE.
- 8.5 Multi-factor authentication (MFA) systems are configured to prevent misuse.
- 8.6 Use of application and system accounts and associated authentication factors is strictly managed.

Overview

Two fundamental principles of identifying and authenticating users are to 1) establish the identity of an individual or process on a computer system, and 2) prove or verify the user associated with the identity is who the user claims to be.

Identification of an individual or process on a computer system is conducted by associating an identity with a person or process through an identifier, such as a user, system, or application ID. These IDs (also referred to as "accounts") fundamentally establish the identity of an individual or process by assigning unique identification to each person or process to distinguish one user or process from another. When each user or process can be uniquely identified, it ensures there is accountability for actions performed by that identity. When such accountability is in place, actions taken can be traced to known and authorized users and processes.

The element used to prove or verify the identity is known as the authentication factor. Authentication factors are 1) something you know, such as a password or passphrase, 2) something you have, such as a token device or smart card, or 3) something you are, such as a biometric element.

The ID and the authentication factor together are considered authentication credentials and are used to gain access to the rights and privileges associated with a user, application, system, or service accounts.

These requirements for identity and authentication are based on industry-accepted security principles and best practices to support the payment ecosystem. *NIST Special Publication 800-63, Digital Identity Guidelines* provides additional information on acceptable frameworks for digital identity and authentication factors. It is important to note that the *NIST Digital Identity Guidelines* is intended for US Federal Agencies and should be viewed in its entirety. Many of the concepts and approaches defined in these guidelines are expected to work with each other and not as standalone parameters.

Note: Unless otherwise stated in the requirement, these requirements apply to **all accounts on all system components**, unless specifically called out in an individual requirement, including but not limited to:

- Point-of-sale accounts
- Accounts with administrative capabilities
- System and application accounts
- All accounts used to view or access cardholder data or to access systems with cardholder data.

This includes accounts used by employees, contractors, consultants, internal and external vendors, and other third parties (for example, for providing support or maintenance services).

Certain requirements are not intended to apply to user accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction. When items do not apply, they are noted directly within the specific requirement.

These requirements do not apply to accounts used by consumers (cardholders).

Refer to [Appendix G](#) for definitions of PCI DSS terms.

Requirements and Testing Procedures		Guidance
8.1 Processes and mechanisms for identifying users and authenticating access to system components are defined and understood.		
Defined Approach Requirements 8.1.1 All security policies and operational procedures that are identified in Requirement 8 are: • Documented. • Kept up to date. • In use. • Known to all affected parties.	Defined Approach Testing Procedures 8.1.1 Examine documentation and interview personnel to verify that security policies and operational procedures that are identified in Requirement 8 are managed in accordance with all elements specified in this requirement.	Purpose Requirement 8.1.1 is about effectively managing and maintaining the various policies and procedures specified throughout Requirement 8. While it is important to define the specific policies or procedures called out in Requirement 8, it is equally important to ensure they are properly documented, maintained, and disseminated. Good Practice It is important to update policies and procedures as needed to address changes in processes, technologies, and business objectives. For this reason, consider updating these documents as soon as possible after a change occurs and not only on a periodic cycle. Definitions Security policies define the entity's security objectives and principles. Operational procedures describe how to perform activities, and define the controls, methods, and processes that are followed to achieve the desired result in a consistent manner and in accordance with policy objectives.
Customized Approach Objective Expectations, controls, and oversight for meeting activities within Requirement 8 are defined and adhered to by affected personnel. All supporting activities are repeatable, consistently applied, and conform to management's intent.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose If roles and responsibilities are not formally assigned, personnel may not be aware of their day-to-day responsibilities and critical activities may not occur. Good Practice Roles and responsibilities may be documented within policies and procedures or maintained within separate documents. As part of communicating roles and responsibilities, entities can consider having personnel acknowledge their acceptance and understanding of their assigned roles and responsibilities. Examples A method to document roles and responsibilities is a responsibility assignment matrix that includes who is responsible, accountable, consulted, and informed (also called a RACI matrix).
8.1.2 Roles and responsibilities for performing activities in Requirement 8 are documented, assigned, and understood.	8.1.2.a Examine documentation to verify that descriptions of roles and responsibilities for performing activities in Requirement 8 are documented and assigned.	
Customized Approach Objective	8.1.2.b Interview personnel with responsibility for performing activities in Requirement 8 to verify that roles and responsibilities are assigned as documented and are understood.	
Day-to-day responsibilities for performing all the activities in Requirement 8 are allocated. Personnel are accountable for successful, continuous operation of these requirements.		

Requirements and Testing Procedures		Guidance
8.2 User identification and related accounts for users and administrators are strictly managed throughout an account's lifecycle.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
8.2.1 All users are assigned a unique ID before access to system components or cardholder data is allowed.	8.2.1.a Interview responsible personnel to verify that all users are assigned a unique ID for access to system components and cardholder data. 8.2.1.b Examine audit logs and other evidence to verify that access to system components and cardholder data can be uniquely identified and associated with individuals.	The ability to trace actions performed on a computer system to an individual establishes accountability and traceability and is fundamental to establishing effective access controls. By ensuring each user is uniquely identified, instead of using one ID for several employees, an organization can maintain individual responsibility for actions and an effective record in the audit log per employee. In addition, this will assist with issue resolution and containment when misuse or malicious intent occurs.
Customized Approach Objective		
All actions by all users are attributable to an individual.		
Applicability Notes		
This requirement is not intended to apply to user accounts within point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 8.2.2 Group, shared, or generic IDs, or other shared authentication credentials are only used when necessary on an exception basis, and are managed as follows: - ID use is prevented unless needed for an exceptional circumstance. - Use is limited to the time needed for the exceptional circumstance. - Business justification for use is documented. - Use is explicitly approved by management. - Individual user identity is confirmed before access to an account is granted. - Every action taken is attributable to an individual user.	Defined Approach Testing Procedures 8.2.2.a Examine user account lists on system components and applicable documentation to verify that shared authentication credentials are only used when necessary, on an exception basis, and are managed in accordance with all elements specified in this requirement. 8.2.2.b Examine authentication policies and procedures to verify processes are defined for shared authentication credentials such that they are only used when necessary, on an exception basis, and are managed in accordance with all elements specified in this requirement. 8.2.2.c Interview system administrators to verify that shared authentication credentials are only used when necessary, on an exception basis, and are managed in accordance with all elements specified in this requirement.	Purpose Group, shared, or generic (or default) IDs are typically delivered with software or operating systems—for example, root or with privileges associated with a specific function, such as an administrator. If multiple users share the same authentication credentials (for example, user ID and password), it becomes impossible to trace system access and activities to an individual. In turn, this prevents an entity from assigning accountability for, or having effective logging of, an individual's actions since a given action could have been performed by anyone in the group with knowledge of the user ID and associated authentication factors. The ability to associate individuals to the actions performed with an ID is essential to provide individual accountability and traceability regarding who performed an action, what action was performed, and when that action occurred. Good Practice If shared IDs are used for any reason, strong management controls need to be established to maintain individual accountability and traceability. <i>(continued on next page)</i>
Customized Approach Objective All actions performed by users with group, shared, or generic IDs are attributable to an individual person.		
Applicability Notes This requirement is not intended to apply to user accounts within point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction.		

Requirements and Testing Procedures		Guidance
8.2.2 (continued)		Examples Tools and techniques can facilitate both management and security of these types of accounts and confirm individual user identity before access to an account is granted. Entities can consider password vaults or other system-managed controls such as the <i>sudo</i> command. An example of an exceptional circumstance is where all other authentication methods have failed, and a shared ID is needed for emergency use or “break the glass” administrator access.
Defined Approach Requirements 8.2.3 Additional requirement for service providers only: Service providers with remote access to customer premises use unique authentication factors for each customer premises. Customized Approach Objective A service provider’s credential used for one customer cannot be used for any other customer.	Defined Approach Testing Procedures 8.2.3 Additional testing procedure for service provider assessments only: Examine authentication policies and procedures and interview personnel to verify that service providers with remote access to customer premises use unique authentication factors for remote access to each customer premises.	Purpose Service providers with remote access to customer premises typically use this access to support POS POI systems or provide other remote services. If a service provider uses the same authentication factors to access multiple customers, all the service provider’s customers can easily be compromised if an attacker compromises that one factor. Criminals know this and deliberately target service providers looking for a shared authentication factor that gives them remote access to many merchants via that single factor. (continued on next page)

Requirements and Testing Procedures		Guidance
Applicability Notes This requirement applies only when the entity being assessed is a service provider. This requirement is not intended to apply to service providers accessing their own shared services environments, where multiple customer environments are hosted. If service provider employees use shared authentication factors to remotely access customer premises, these factors must be unique per customer and managed in accordance with Requirement 8.2.2.		Examples Technologies such as multi-factor mechanisms that provide a unique credential for each connection (such as a single-use password) could also meet the intent of this requirement.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 8.2.4 Addition, deletion, and modification of user IDs, authentication factors, and other identifier objects are managed as follows: - Authorized with the appropriate approval. - Implemented with only the privileges specified on the documented approval.	Defined Approach Testing Procedures 8.2.4 Examine documented authorizations across various phases of the account lifecycle (additions, modifications, and deletions) and examine system settings to verify the activity has been managed in accordance with all elements specified in this requirement.	Purpose It is imperative that the lifecycle of a user ID (additions, deletions, and modifications) is controlled so that only authorized accounts can perform functions, actions are auditable, and privileges are limited to only what is required. Attackers often compromise an existing account and then escalate the privileges of that account to perform unauthorized acts, or they may create new IDs to continue their activity in the background. It is essential to detect and respond when user IDs are created or changed outside the normal change process or without corresponding authorization.
Customized Approach Objective Lifecycle events for user IDs and authentication factors cannot occur without appropriate authorization.		
Applicability Notes This requirement applies to all user accounts, including employees, contractors, consultants, temporary workers, and third-party vendors.		
Defined Approach Requirements 8.2.5 Access for terminated users is immediately revoked.	Defined Approach Testing Procedures 8.2.5.a Examine information sources for terminated users and review current user access lists—for both local and remote access—to verify that terminated user IDs have been deactivated or removed from the access lists.	Purpose If an employee or third party/vendor has left the company and still has access to the network via their user account, unnecessary or malicious access to cardholder data could occur—either by the former employee or by a malicious user who exploits the old and/or unused account.
Customized Approach Objective The accounts of terminated users cannot be used.	8.2.5.b Interview responsible personnel to verify that all physical authentication factors—such as, smart cards, tokens, etc.—have been returned or deactivated for terminated users.	

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 8.2.6 Inactive user accounts are removed or disabled within 90 days of inactivity.	Defined Approach Testing Procedures 8.2.6 Examine user accounts and last logon information, and interview personnel to verify that any inactive user accounts are removed or disabled within 90 days of inactivity.	Purpose Accounts that are not used regularly are often targets of attack since it is less likely that any changes, such as a changed password, will be noticed. As such, these accounts may be more easily exploited and used to access cardholder data. Good Practice Where it may be reasonably anticipated that an account will not be used for an extended period of time, such as an extended leave of absence, the account should be disabled as soon as the leave begins, rather than waiting 90 days.
Customized Approach Objective Inactive user accounts cannot be used.		
Defined Approach Requirements 8.2.7 Accounts used by third parties to access, support, or maintain system components via remote access are managed as follows: • Enabled only during the time period needed and disabled when not in use. • Use is monitored for unexpected activity.	Defined Approach Testing Procedures 8.2.7 Interview personnel, examine documentation for managing accounts, and examine evidence to verify that accounts used by third parties for remote access are managed according to all elements specified in this requirement.	Purpose Allowing third parties to have 24/7 access into an entity's systems and networks in case they need to provide support increases the chances of unauthorized access. This access could result in an unauthorized user in the third party's environment or a malicious individual using the always-available external entry point into an entity's network. Where third parties do need access 24/7, it should be documented, justified, monitored, and tied to specific service reasons. <i>(continued on next page)</i>

Requirements and Testing Procedures		Guidance
Customized Approach Objective Third-party remote access cannot be used except where specifically authorized and use is overseen by management.		Good Practice Enabling access only for the time periods needed and disabling it as soon as it is no longer required helps prevent misuse of these connections. Additionally, consider assigning third parties a start and stop date for their access in accordance with their service contract. Monitoring third-party access helps ensure that third parties are accessing only the systems necessary and only during approved time frames. Any unusual activity using third-party accounts should be followed up and resolved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 8.2.8 If a user session has been idle for more than 15 minutes, the user is required to re-authenticate to re-activate the terminal or session.	Defined Approach Testing Procedures 8.2.8 Examine system configuration settings to verify that system/session idle timeout features for user sessions have been set to 15 minutes or less.	Purpose When users walk away from an open machine with access to system components or cardholder data, there is a risk that the machine may be used by others in the user's absence, resulting in unauthorized account access and/or misuse.
Customized Approach Objective A user session cannot be used except by the authorized user.		Good Practice The re-authentication can be applied either at the system level to protect all sessions running on that machine or at the application level.
Applicability Notes This requirement is not intended to apply to user accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction. This requirement is not meant to prevent legitimate activities from being performed while the console/PC is unattended.		Entities may also want to consider staging controls in succession to further restrict the access of an unattended session as time passes. For example, the screensaver may activate after 15 minutes and log off the user after an hour. However, timeout controls must balance the risk of access and exposure with the impact to the user and purpose of the access. If a user needs to run a program from an unattended computer, the user can log in to the computer to initiate the program, and then "lock" the computer so that no one else can use the user's login while the computer is unattended.
		Examples One way to meet this requirement is to configure an automated screensaver to launch whenever the console is idle for 15 minutes and requiring the logged-in user to enter their password to unlock the screen.

Requirements and Testing Procedures		Guidance
8.3 Strong authentication for users and administrators is established and managed.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
8.3.1 All user access to system components for users and administrators is authenticated via at least one of the following authentication factors: • Something you know, such as a password or passphrase. • Something you have, such as a token device or smart card. • Something you are, such as a biometric element.	8.3.1.a Examine documentation describing the authentication factor(s) used to verify that user access to system components is authenticated via at least one authentication factor specified in this requirement.	When used in addition to unique IDs, an authentication factor helps protect user IDs from being compromised, since the attacker needs to have the unique ID and compromise the associated authentication factor(s). Good Practice A common approach for a malicious individual to compromise a system is to exploit weak or nonexistent authentication factors (for example, passwords/passphrases). Requiring strong authentication factors helps protect against this attack. Further Information See fidoalliance.org for more information about using tokens, smart cards, or biometrics as authentication factors.
Customized Approach Objective An account cannot be accessed except with a combination of user identity and an authentication factor.	8.3.1.b For each type of authentication factor used with each type of system component, observe an authentication to verify that authentication is functioning consistently with documented authentication factor(s).	
Applicability Notes This requirement is not intended to apply to user accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction. This requirement does not supersede multi-factor authentication (MFA) requirements but applies to those in-scope systems not otherwise subject to MFA requirements. A digital certificate is a valid option for “something you have” if it is unique for a particular user.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
8.3.2 Strong cryptography is used to render all authentication factors unreadable during transmission and storage on all system components.	8.3.2.a Examine vendor documentation and system configuration settings to verify that authentication factors are rendered unreadable with strong cryptography during transmission and storage.	
	8.3.2.b Examine repositories of authentication factors to verify that they are unreadable during storage.	
	8.3.2.c Examine data transmissions to verify that authentication factors are unreadable during transmission.	
Customized Approach Objective		
Cleartext authentication factors cannot be obtained, derived, or reused from the interception of communications or from stored data.		Network devices and applications have been known to transmit unencrypted, readable authentication factors (such as passwords and passphrases) across the network and/or store these values without encryption. As a result, a malicious individual can easily intercept this information during transmission using a “sniffer,” or directly access unencrypted authentication factors in files where they are stored, and then use this data to gain unauthorized access.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 8.3.3 User identity is verified before modifying any authentication factor.	Defined Approach Testing Procedures 8.3.3 Examine procedures for modifying authentication factors and observe security personnel to verify that when a user requests a modification of an authentication factor, the user's identity is verified before the authentication factor is modified.	Purpose Malicious individuals use "social engineering" techniques to impersonate a user of a system — for example, calling a help desk and acting as a legitimate user—to have an authentication factor changed so they can use a valid user ID. Requiring positive identification of a user reduces the probability of this type of attack succeeding.
Customized Approach Objective Unauthorized individuals cannot gain system access by impersonating the identity of an authorized user.		Good Practice Modifications to authentication factors for which user identity should be verified include but are not limited to performing password resets, provisioning new hardware or software tokens, and generating new keys.
		Examples Methods to verify a user's identity include a secret question/answer, knowledge-based information, and calling the user back at a known and previously established phone number.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 8.3.4 Invalid authentication attempts are limited by: • Locking out the user ID after not more than 10 attempts. • Setting the lockout duration to a minimum of 30 minutes or until the user's identity is confirmed.	Defined Approach Testing Procedures 8.3.4.a Examine system configuration settings to verify that authentication parameters are set to require that user accounts be locked out after not more than 10 invalid logon attempts. 8.3.4.b Examine system configuration settings to verify that password parameters are set to require that once a user account is locked out, it remains locked for a minimum of 30 minutes or until the user's identity is confirmed.	Purpose Without account-lockout mechanisms in place, an attacker can continually try to guess a password through manual or automated tools (for example, password cracking) until the attacker succeeds and gains access to a user's account. If an account is locked out due to someone continually trying to guess a password, controls to delay reactivation of the locked account stop the malicious individual from guessing the password, as they will have to stop for a minimum of 30 minutes until the account is reactivated. Good Practice Before reactivating a locked account, the user's identity should be confirmed. For example, the administrator or help desk personnel can validate that the actual account owner is requesting reactivation, or there may be password reset self-service mechanisms that the account owner uses to verify their identity.
Customized Approach Objective An authentication factor cannot be guessed in a brute force, online attack.		
Applicability Notes This requirement is not intended to apply to user accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction.		
Defined Approach Requirements 8.3.5 If passwords/passphrases are used as authentication factors to meet Requirement 8.3.1, they are set and reset for each user as follows: • Set to a unique value for first-time use and upon reset. • Forced to be changed immediately after the first use.	Defined Approach Testing Procedures 8.3.5 Examine procedures for setting and resetting passwords/passphrases (if used as authentication factors to meet Requirement 8.3.1) and observe security personnel to verify that passwords/passphrases are set and reset in accordance with all elements specified in this requirement.	Purpose If the same password/passphrase is used for every new user, an internal user, former employee, or malicious individual may know or easily discover the value and use it to gain access to accounts before the authorized user attempts to use the password.
Customized Approach Objective An initial or reset password/passphrase assigned to a user cannot be used by an unauthorized user.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
8.3.6 If passwords/passphrases are used as authentication factors to meet Requirement 8.3.1, they meet the following minimum level of complexity: - A minimum length of 12 characters (or IF the system does not support 12 characters, a minimum length of eight characters). - Contain both numeric and alphabetic characters.	8.3.6 Examine system configuration settings to verify that user password/passphrase complexity parameters are set in accordance with all elements specified in this requirement.	Strong passwords/passphrases may be the first line of defense into a network since a malicious individual will often first try to find accounts with weak, static, or non-existent passwords. If passwords are short or easily guessable, it is relatively easy for a malicious individual to find these weak accounts and compromise a network under the guise of a valid user ID. Good Practice Password/passphrase strength is dependent on password/passphrase complexity, length, and randomness. Passwords/passphrases should be sufficiently complex, so they are impractical for an attacker to guess or otherwise discover its value. Entities can consider adding increased complexity by requiring the use of special characters and upper- and lower-case characters, in addition to the minimum standards outlined by this requirement. Additional complexity increases the time required for offline brute force attacks of hashed passwords/passphrases. Another option for increasing the resistance of passwords to guessing attacks is by comparing proposed password/passphrases to a bad password list and having users provide new passwords for any passwords found on the list.
Customized Approach Objective		
A guessed password/passphrase cannot be verified by either an online or offline brute force attack.		
Applicability Notes		
This requirement is not intended to apply to: - User accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction. - Application or system accounts, which are governed by requirements in section 8.6. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i> Until 31 March 2025, passwords must be a minimum length of seven characters in accordance with PCI DSS v3.2.1 Requirement 8.2.3.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
8.3.7 Individuals are not allowed to submit a new password/passphrase that is the same as any of the last four passwords/passphrases used.	8.3.7 Examine system configuration settings to verify that password parameters are set to require that new passwords/passphrases cannot be the same as the four previously used passwords/passphrases.	If password history is not maintained, the effectiveness of changing passwords is reduced, as previous passwords can be reused over and over. Requiring that passwords cannot be reused for a period reduces the likelihood that passwords that have been guessed or brute-forced will be re-used in the future. Passwords or passphrases may have previously been changed due to suspicion of compromise or because the password or passphrase exceeded its effective use period, both of which are reasons why previously used passwords should not be reused.
Customized Approach Objective		
A previously used password cannot be used to gain access to an account for at least 12 months.		
Applicability Notes		
This requirement is not intended to apply to user accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
8.3.8 Authentication policies and procedures are documented and communicated to all users including: - Guidance on selecting strong authentication factors. - Guidance for how users should protect their authentication factors. - Instructions not to reuse previously used passwords/passphrases. - Instructions to change passwords/passphrases if there is any suspicion or knowledge that the password/passphrases have been compromised and how to report the incident.	8.3.8.a Examine procedures and interview personnel to verify that authentication policies and procedures are distributed to all users.	Communicating authentication policies and procedures to all users helps them to understand and abide by the policies.
	8.3.8.b Review authentication policies and procedures that are distributed to users and verify they include the elements specified in this requirement.	Good Practice Guidance on selecting strong passwords may include suggestions to help personnel select hard-to-guess passwords that do not contain dictionary words or information about the user, such as the user ID, names of family members, date of birth, etc.
	8.3.8.c Interview users to verify that they are familiar with authentication policies and procedures.	Guidance for protecting authentication factors may include not writing down passwords or not saving them in insecure files, and being alert to malicious individuals who may try to exploit their passwords (for example, by calling an employee and asking for their password so the caller can “troubleshoot a problem”).
Customized Approach Objective		Alternatively, entities can implement processes to confirm passwords meet password policy, for example, by comparing password choices to a list of unacceptable passwords and having users choose a new password for any that match with one on the list. Instructing users to change passwords if there is a chance the password is no longer secure can prevent malicious users from using a legitimate password to gain unauthorized access.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
8.3.9 If passwords/passphrases are used as the only authentication factor for user access (i.e., in any single-factor authentication implementation) then either: • Passwords/passphrases are changed at least once every 90 days, OR • The security posture of accounts is dynamically analyzed, and real-time access to resources is automatically determined accordingly.	8.3.9 If passwords/passphrases are used as the only authentication factor for user access, inspect system configuration settings to verify that passwords/passphrases are managed in accordance with ONE of the elements specified in this requirement.	Access to in-scope system components that are not in the CDE may be provided using a single authentication factor, such as a password/passphrase, token device or smart card, or biometric attribute. Where passwords/passphrases are employed as the only authentication factor for such access, additional controls are required to protect the integrity of the password/passphrase. Good Practice Passwords/passphrases that are valid for a long time without a change provide malicious individuals with more time to break the password/phrase. Periodically changing passwords offers less time for a malicious individual to crack a password/passphrase and less time to use a compromised password. Using a password/passphrase as the only authentication factor provides a single point of failure if compromised. Therefore, in these implementations, controls are needed to minimize how long malicious activity could occur via a compromised password/passphrase. <i>(continued on next page)</i>
Customized Approach Objective		
An undetected compromised password/passphrase cannot be used indefinitely.		
Applicability Notes		
This requirement does not apply to in-scope system components where MFA is used. This requirement is not intended to apply to user accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction. This requirement does not apply to service providers' customer accounts but does apply to accounts for service provider personnel.		

Requirements and Testing Procedures		Guidance
8.3.9 (continued)		Dynamically analyzing an account's security posture is another option that allows for more rapid detection and response to address potentially compromised credentials. Such analysis takes a number of data points, which may include device integrity, location, access times, and the resources accessed to determine in real time whether an account can be granted access to a requested resource. In this way, access can be denied and accounts blocked if it is suspected that authentication credentials have been compromised. Further Information For information about using dynamic analysis to manage user access to resources, see <i>NIST SP 800-207 Zero Trust Architecture</i>.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Using a password/passphrase as the only authentication factor provides a single point of failure if compromised. Therefore, in these implementations, controls are needed to minimize how long malicious activity could occur via a compromised password/passphrase. Good Practice Passwords/passphrases that are valid for a long time without a change provide malicious individuals with more time to break the password/phrase. Periodically changing passwords offers less time for a malicious individual to crack a password/passphrase and less time to use a compromised password.
8.3.10 Additional requirement for service providers only: If passwords/passphrases are used as the only authentication factor for customer user access to cardholder data (i.e., in any single-factor authentication implementation), then guidance is provided to customer users including: - Guidance for customers to change their user passwords/passphrases periodically. - Guidance as to when, and under what circumstances, passwords/passphrases are to be changed.	8.3.10 Additional testing procedure for service provider assessments only: If passwords/passphrases are used as the only authentication factor for customer user access to cardholder data, examine guidance provided to customer users to verify that the guidance includes all elements specified in this requirement.	
Customized Approach Objective Passwords/passphrases for service providers' customers cannot be used indefinitely.		
Applicability Notes This requirement applies only when the entity being assessed is a service provider. This requirement does not apply to accounts of consumer users accessing their own payment card information. <i>This requirement for service providers will be superseded by Requirement 8.3.10.1 once 8.3.10.1 becomes effective.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
8.3.10.1 Additional requirement for service providers only: If passwords/passphrases are used as the only authentication factor for customer user access (i.e., in any single-factor authentication implementation) then either: • Passwords/passphrases are changed at least once every 90 days, OR • The security posture of accounts is dynamically analyzed, and real-time access to resources is automatically determined accordingly.	8.3.10.1 Additional testing procedure for service provider assessments only: If passwords/passphrases are used as the only authentication factor for customer user access, inspect system configuration settings to verify that passwords/passphrases are managed in accordance with ONE of the elements specified in this requirement.	Using a password/passphrase as the only authentication factor provides a single point of failure if compromised. Therefore, in these implementations, controls are needed to minimize how long malicious activity could occur via a compromised password/passphrase. Good Practice Passwords/passphrases that are valid for a long time without a change provide malicious individuals with more time to break the password/phrase. Periodically changing passwords offers less time for a malicious individual to crack a password/passphrase and less time to use a compromised password. Dynamically analyzing an account's security posture is another option that allows for more rapid detection and response to address potentially compromised credentials. Such analysis takes a number of data points which may include device integrity, location, access times, and the resources accessed to determine in real time whether an account can be granted access to a requested resource. In this way, access can be denied and accounts blocked if it is suspected that account credentials have been compromised. Further Information For information about using dynamic analysis to manage user access to resources, refer to <i>NIST SP 800-207 Zero Trust Architecture</i>.
Customized Approach Objective		
Passwords/passphrases for service providers' customers cannot be used indefinitely.		
Applicability Notes		
This requirement applies only when the entity being assessed is a service provider. This requirement does not apply to accounts of consumer users accessing their own payment card information. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i> Until this requirement is effective on 31 March 2025, service providers may meet either Requirement 8.3.10 or 8.3.10.1.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose If multiple users can use authentication factors such as tokens, smart cards, and certificates, it may be impossible to identify the individual using the authentication mechanism. Good Practice Having physical and/or logical controls (for example, a PIN, biometric data, or a password) to uniquely authenticate the user of the account will prevent unauthorized users from gaining access to the user account through use of a shared authentication factor.
8.3.11 Where authentication factors such as physical or logical security tokens, smart cards, or certificates are used: - Factors are assigned to an individual user and not shared among multiple users. - Physical and/or logical controls ensure only the intended user can use that factor to gain access.	8.3.11.a Examine authentication policies and procedures to verify that procedures for using authentication factors such as physical security tokens, smart cards, and certificates are defined and include all elements specified in this requirement.	
	8.3.11.b Interview security personnel to verify authentication factors are assigned to an individual user and not shared among multiple users.	
Customized Approach Objective	8.3.11.c Examine system configuration settings and/or observe physical controls, as applicable, to verify that controls are implemented to ensure only the intended user can use that factor to gain access.	
An authentication factor cannot be used by anyone other than the user to which it is assigned.		

Requirements and Testing Procedures		Guidance
8.4 Multi-factor authentication (MFA) is implemented to secure access into the CDE.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Requiring more than one type of authentication factor reduces the probability that an attacker can gain access to a system by masquerading as a legitimate user, because the attacker would need to compromise multiple authentication factors. This is especially true in environments where traditionally the single authentication factor employed was something a user knows such as a password or passphrase. Good Practice Implementing MFA for non-console administrative access to in-scope system components that are not part of the CDE will help prevent unauthorized users from using a single factor to gain access and compromise in-scope system components. Definitions Using one factor twice (for example, using two separate passwords) is not considered multi-factor authentication.
8.4.1 MFA is implemented for all non-console access into the CDE for personnel with administrative access.	8.4.1.a Examine network and/or system configurations to verify MFA is required for all non-console into the CDE for personnel with administrative access.	
	8.4.1.b Observe administrator personnel logging into the CDE and verify that MFA is required.	
Customized Approach Objective		
Administrative access to the CDE cannot be obtained by the use of a single authentication factor.		
Applicability Notes		
The requirement for MFA for non-console administrative access applies to all personnel with elevated or increased privileges accessing the CDE via a non-console connection—that is, via logical access occurring over a network interface rather than via a direct, physical connection.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Requiring more than one type of authentication factor reduces the probability that an attacker can gain access to a system by masquerading as a legitimate user, because the attacker would need to compromise multiple authentication factors. This is especially true in environments where traditionally the single authentication factor employed was something a user knows such as a password or passphrase. <i>(continued on next page)</i>
8.4.2 MFA is implemented for all non-console access into the CDE.	8.4.2.a Examine network and/or system configurations to verify MFA is implemented for all non-console access into the CDE.	
Customized Approach Objective	8.4.2.b Observe personnel logging in to the CDE and examine evidence to verify that MFA is required.	
Access into the CDE cannot be obtained by the use of a single authentication factor.		

Requirements and Testing Procedures		Guidance
Applicability Notes This requirement does not apply to: • Application or system accounts performing automated functions. • User accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction. • User accounts that are only authenticated with phishing-resistant authentication factors. MFA is required for both types of access specified in Requirements 8.4.2 and 8.4.3. Therefore, applying MFA to one type of access does not replace the need to apply another instance of MFA to the other type of access. If an individual first connects to the entity's network via remote access, and then later initiates a connection into the CDE from within the network, per this requirement the individual would authenticate using MFA twice, once when connecting via remote access to the entity's network and once when connecting from the entity's network into the CDE. <i>(continued on next page)</i>		Definitions Using one factor twice (for example, using two separate passwords) is not considered multi-factor authentication. Refer to Appendix G for the definition of “phishing resistant authentication.”

Requirements and Testing Procedures	Guidance
The MFA requirements apply for all types of system components, including cloud, hosted systems, and on-premises applications, network security devices, workstations, servers, and endpoints, and includes access directly to an entity's networks or systems as well as web-based access to an application or function. MFA for access into the CDE can be implemented at the network or system/application level; it does not have to be applied at both levels. For example, if MFA is used when a user connects to the CDE network, it does not have to be used when the user logs into each system or application within the CDE. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>	

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Requiring more than one type of authentication factor reduces the probability that an attacker can gain access to a system by masquerading as a legitimate user, because the attacker would need to compromise multiple authentication factors. This is especially true in environments where traditionally the single authentication factor employed was something a user knows, such as a password or passphrase. Definitions Multi-factor authentication (MFA) requires an individual to present a minimum of two of the three authentication factors specified in Requirement 8.3.1 before access is granted. Using one factor twice (for example, using two separate passwords) is not considered multi-factor authentication. <i>(continued on next page)</i>
8.4.3 MFA is implemented for all remote access originating from outside the entity's network that could access or impact the CDE.	8.4.3.a Examine network and/or system configurations for remote access servers and systems to verify MFA is required in accordance with all elements specified in this requirement.	
Customized Approach Objective Remote access to the entity's network cannot be obtained by using a single authentication factor.	8.4.3.b Observe personnel (for example, users and administrators) and third parties connecting remotely to the network and verify that multi-factor authentication is required.	

Requirements and Testing Procedures		Guidance
Applicability Notes The requirement for MFA for remote access originating from outside the entity's network applies to all user accounts that can access the network remotely, where that remote access leads to or could lead to access into the CDE. This includes all remote access by personnel (users and administrators), and third parties (including, but not limited to, vendors, suppliers, service providers, and customers). If remote access is to a part of the entity's network that is properly segmented from the CDE, such that remote users cannot access or impact the CDE, MFA for remote access to that part of the network is not required. However, MFA is required for any remote access to networks with access to the CDE and is recommended for all remote access to the entity's networks. The MFA requirements apply for all types of system components, including cloud, hosted systems, and on-premises applications, network security devices, workstations, servers, and endpoints, and includes access directly to an entity's networks or systems as well as web-based access to an application or function.		

Requirements and Testing Procedures		Guidance
8.5 Multi-factor authentication (MFA) systems are configured to prevent misuse.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
8.5.1 MFA systems are implemented as follows: - The MFA system is not susceptible to replay attacks. - MFA systems cannot be bypassed by any users, including administrative users unless specifically documented, and authorized by management on an exception basis, for a limited time period. - At least two different types of authentication factors are used. - Success of all authentication factors is required before access is granted.	8.5.1.a Examine vendor system documentation to verify that the MFA system is not susceptible to replay attacks.	Poorly configured MFA systems can be bypassed by attackers. This requirement therefore addresses configuration of MFA system(s) that provide MFA for users accessing system components in the CDE. Definitions Using one type of factor twice (for example, using two separate passwords) is not considered multi-factor authentication. A replay attack is when an attacker intercepts a valid transmission of data and then resends or redirects this communication for malicious purposes. In MFA implementations, replay attacks are typically used to gain unauthorized access by leveraging legitimate credentials. Examples Examples of methods to help protect against replay attacks include, but are not limited to: - Unique session identifiers and session keys - Timestamps - Time-based, one-time passwords or passcodes - Anti-replay mechanisms that detect and reject duplicated authentication attempts. <i>(continued on next page)</i>
	8.5.1.b Examine system configurations for the MFA implementation to verify it is configured in accordance with all elements specified in this requirement.	
	8.5.1.c Interview responsible personnel and observe processes to verify that any requests to bypass MFA are specifically documented and authorized by management on an exception basis, for a limited time period.	
	8.5.1.d Observe personnel logging into system components in the CDE to verify that access is granted only after all authentication factors are successful.	
	8.5.1.e Observe personnel connecting remotely from outside the entity's network to verify that access is granted only after all authentication factors are successful.	
Customized Approach Objective		
MFA systems are resistant to attack and strictly control any administrative overrides.		

Requirements and Testing Procedures		Guidance
Applicability Notes <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		Further Information For more information about MFA systems and features, refer to the following: PCI SSC's <i>Information Supplement: Multi-Factor Authentication</i> PCI SSC's Frequently Asked Questions (FAQs) on this topic.

Requirements and Testing Procedures		Guidance
8.6 Use of application and system accounts and associated authentication factors is strictly managed.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
8.6.1 If accounts used by systems or applications can be used for interactive login, they are managed as follows: - Interactive use is prevented unless needed for an exceptional circumstance. - Interactive use is limited to the time needed for the exceptional circumstance. - Business justification for interactive use is documented. - Interactive use is explicitly approved by management. - Individual user identity is confirmed before access to account is granted. - Every action taken is attributable to an individual user.	8.6.1 Examine application and system accounts that can be used interactively and interview administrative personnel to verify that application and system accounts are managed in accordance with all elements specified in this requirement.	Like individual user accounts, system and application accounts require accountability and strict management to ensure they are used only for the intended purpose and are not misused. Attackers often compromise system or application accounts to gain access to cardholder data. Good Practice Where possible, configure system and application accounts to disallow interactive login to prevent unauthorized individuals from logging in and using the account with its associated system privileges, and to limit the machines and devices on which the account can be used. Definitions Interactive login is the ability for a person to log into a system or application account in the same manner as a normal user account. Using system and application accounts this way means there is no accountability and traceability of actions taken by the user. Refer to Appendix G for the definition of “application and system accounts.”
Customized Approach Objective		
When used interactively, all actions with accounts designated as system or application accounts are authorized and attributable to an individual person.		
Applicability Notes		
<i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Not properly protecting passwords/passphrases used by application and system accounts, especially if those accounts can be used for interactive login, increases the risk and success of unauthorized use of those privileged accounts. Good Practice Changing these values due to suspected or confirmed disclosure can be particularly difficult to implement. Tools can facilitate both management and security of authentication factors for application and system accounts. For example, consider password vaults or other system-managed controls.
8.6.2 Passwords/passphrases for any application and system accounts that can be used for interactive login are not hard coded in scripts, configuration/property files, or bespoke and custom source code.	8.6.2.a Interview personnel and examine system development procedures to verify that processes are defined for application and system accounts that can be used for interactive login, specifying that passwords/passphrases are not hard coded in scripts, configuration/property files, or bespoke and custom source code.	
Customized Approach Objective Passwords/passphrases used by application and system accounts cannot be used by unauthorized personnel.	8.6.2.b Examine scripts, configuration/property files, and bespoke and custom source code for application and system accounts that can be used for interactive login, to verify passwords/passphrases for those accounts are not present.	
Applicability Notes Stored passwords/passphrases are required to be encrypted in accordance with PCI DSS Requirement 8.3.2. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
8.6.3 Passwords/passphrases for any application and system accounts are protected against misuse as follows: • Passwords/passphrases are changed periodically (at the frequency defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1) and upon suspicion or confirmation of compromise. • Passwords/passphrases are constructed with sufficient complexity appropriate for how frequently the entity changes the passwords/passphrases.	8.6.3.a Examine policies and procedures to verify that procedures are defined to protect passwords/passphrases for application or system accounts against misuse in accordance with all elements specified in this requirement.	Systems and application accounts pose more inherent security risk than user accounts because they often run in an elevated security context, with access to systems that may not be typically granted to user accounts, such as programmatic access to databases, etc. As a result, special consideration must be made to protect passwords/passphrases used for application and system accounts. Good Practice Entities should consider the following risk factors when determining how to protect application and system passwords/passphrases against misuse: • How securely the passwords/passphrases are stored (for example, whether they are stored in a password vault). • Staff turnover. • The number of people with access to the authentication factor. • Whether the account can be used for interactive login. • Whether the security posture of accounts is dynamically analyzed, and real-time access to resources is automatically determined accordingly (see Requirement 8.3.9). All these elements affect the level of risk for application and system accounts and might impact the security of systems accessed by the system and application accounts. <i>(continued on next page)</i>
	8.6.3.b Examine the entity's targeted risk analysis for the change frequency and complexity for passwords/passphrases for application and system accounts to verify the risk analysis was performed in accordance with all elements specified in Requirement 12.3.1 and addresses: • The frequency defined for periodic changes to application and system passwords/passphrases. • The complexity defined for passwords/passphrases and appropriateness of the complexity relative to the frequency of changes.	
Customized Approach Objective	8.6.3.c Interview responsible personnel and examine system configuration settings to verify that passwords/passphrases for any application and system accounts are protected against misuse in accordance with all elements specified in this requirement.	
Applicability Notes		
<i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures	Guidance
8.6.3 <i>(continued)</i>	Entities should correlate their selected change frequency for application and system passwords/passphrases with their selected complexity for those passwords/passphrases – i.e., the complexity should be more rigorous when passwords/passphrases are changed infrequently and can be less rigorous when changed more frequently. For example, a longer change frequency is more justifiable when passwords/passphrases complexity is set to 36 alphanumeric characters with upper- and lower-case letters, numbers, and special characters. Best practices are to consider password changes at least once a year, a password/passphrase length of at least 15 characters, and complexity for the passwords/passphrase of alphanumeric characters, with upper- and lower-case letters, and special characters. Further Information For information about variability and equivalency of password strength for passwords/passphrases of different formats, see the industry standards (for example, the current version of <i>NIST SP 800-63 Digital Identity Guidelines</i>).

Regularly Monitor and Test Networks

Requirement 10: Log and Monitor All Access to System Components and Cardholder Data

Sections

- 10.1** Processes and mechanisms for logging and monitoring all access to system components and cardholder data are defined and understood.
- 10.2** Audit logs are implemented to support the detection of anomalies and suspicious activity, and the forensic analysis of events.
- 10.3** Audit logs are protected from destruction and unauthorized modifications.
- 10.4** Audit logs are reviewed to identify anomalies or suspicious activity.
- 10.5** Audit log history is retained and available for analysis.
- 10.6** Time-synchronization mechanisms support consistent time settings across all systems.
- 10.7** Failures of critical security control systems are detected, reported, and responded to promptly.

Overview

Logging mechanisms and the ability to track user activities are critical in preventing, detecting, or minimizing the impact of a data compromise. The presence of logs on all system components and in the cardholder data environment (CDE) allows thorough tracking, alerting, and analysis when something does go wrong. Determining the cause of a compromise is difficult, if not impossible, without system activity logs.

This requirement applies to user activities, including those by employees, contractors, consultants, and internal and external vendors, and other third parties (for example, those providing support or maintenance services).

These requirements do not apply to user activity of consumers (cardholders).

Refer to [Appendix G](#) for definitions of PCI DSS terms.

Requirements and Testing Procedures		Guidance
10.1 Processes and mechanisms for logging and monitoring all access to system components and cardholder data are defined and understood.		
Defined Approach Requirements 10.1.1 All security policies and operational procedures that are identified in Requirement 10 are: • Documented. • Kept up to date. • In use. • Known to all affected parties.	Defined Approach Testing Procedures 10.1.1 Examine documentation and interview personnel to verify that security policies and operational procedures identified in Requirement 10 are managed in accordance with all elements specified in this requirement.	Purpose Requirement 10.1.1 is about effectively managing and maintaining the various policies and procedures specified throughout Requirement 10. While it is important to define the specific policies or procedures called out in Requirement 10, it is equally important to ensure they are properly documented, maintained, and disseminated. Good Practice It is important to update policies and procedures as needed to address changes in processes, technologies, and business objectives. For this reason, consider updating these documents as soon as possible after a change occurs and not only on a periodic cycle. Definitions Security policies define the entity's security objectives and principles. Operational procedures describe how to perform activities, and define the controls, methods, and processes that are followed to achieve the desired result in a consistent manner and in accordance with policy objectives.
Customized Approach Objective Expectations, controls, and oversight for meeting activities within Requirement 10 are defined and adhered to by affected personnel. All supporting activities are repeatable, consistently applied, and conform to management's intent.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 10.1.2 Roles and responsibilities for performing activities in Requirement 10 are documented, assigned, and understood.	Defined Approach Testing Procedures 10.1.2.a Examine documentation to verify that descriptions of roles and responsibilities for performing activities in Requirement 10 are documented and assigned. 10.1.2.b Interview personnel with responsibility for performing activities in Requirement 10 to verify that roles and responsibilities are assigned as defined and are understood.	Purpose If roles and responsibilities are not formally assigned, personnel may not be aware of their day-to-day responsibilities and critical activities may not occur. Good Practice Roles and responsibilities may be documented within policies and procedures or maintained within separate documents. As part of communicating roles and responsibilities, entities can consider having personnel acknowledge their acceptance and understanding of their assigned roles and responsibilities. Examples A method to document roles and responsibilities is a responsibility assignment matrix that includes who is responsible, accountable, consulted, and informed (also called a RACI matrix).
Customized Approach Objective Day-to-day responsibilities for performing all the activities in Requirement 10 are allocated. Personnel are accountable for successful, continuous operation of these requirements.		

Requirements and Testing Procedures		Guidance
10.2 Audit logs are implemented to support the detection of anomalies and suspicious activity, and the forensic analysis of events.		
Defined Approach Requirements 10.2.1 Audit logs are enabled and active for all system components and cardholder data.	Defined Approach Testing Procedures 10.2.1 Interview the system administrator and examine system configurations to verify that audit logs are enabled and active for all system components.	Purpose Audit logs must exist for all system components. Audit logs send alerts the system administrator, provides data to other monitoring mechanisms, such as intrusion-detection systems (IDS) and security information and event monitoring systems (SIEM) tools, and provide a history trail for post-incident investigation. Logging and analyzing security-relevant events enable an organization to identify and trace potentially malicious activities. Good Practice When an entity considers which information to record in their logs, it is important to remember that information stored in audit logs is sensitive and should be protected per requirements in this standard. Care should be taken to only store essential information in the audit logs to minimize risk.
Customized Approach Objective Records of all activities affecting system components and cardholder data are captured.		
Defined Approach Requirements 10.2.1.1 Audit logs capture all individual user access to cardholder data.	Defined Approach Testing Procedures 10.2.1.1 Examine audit log configurations and log data to verify that all individual user access to cardholder data is logged.	Purpose It is critical to have a process or system that links user access to system components accessed. Malicious individuals could obtain knowledge of a user account with access to systems in the CDE, or they could create a new, unauthorized account to access cardholder data. Good Practice A record of all individual access to cardholder data can identify which accounts may have been compromised or misused.
Customized Approach Objective Records of all individual user access to cardholder data are captured.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 10.2.1.2 Audit logs capture all actions taken by any individual with administrative access, including any interactive use of application or system accounts.	Defined Approach Testing Procedures 10.2.1.2 Examine audit log configurations and log data to verify that all actions taken by any individual with administrative access, including any interactive use of application or system accounts, are logged.	Purpose Accounts with increased access privileges, such as the “administrator” or “root” account, have the potential to significantly impact the security or operational functionality of a system. Without a log of the activities performed, an organization is cannot trace any issues resulting from an administrative mistake or misuse of privilege back to the specific action and account. Definitions The functions or activities considered to be administrative are beyond those performed by regular users as part of routine business functions. Refer to Appendix G for the definition of “administrative access.”
Customized Approach Objective Records of all actions performed by individuals with elevated privileges are captured.		
Defined Approach Requirements 10.2.1.3 Audit logs capture all access to audit logs.	Defined Approach Testing Procedures 10.2.1.3 Examine audit log configurations and log data to verify that access to all audit logs is captured.	Purpose Malicious users often attempt to alter audit logs to hide their actions. A record of access allows an organization to trace any inconsistencies or potential tampering of the logs to an individual account. Having logs identify changes, additions, and deletions to the audit logs can help retrace steps made by unauthorized personnel.
Customized Approach Objective Records of all access to audit logs are captured.		
Defined Approach Requirements 10.2.1.4 Audit logs capture all invalid logical access attempts.	Defined Approach Testing Procedures	Purpose Malicious individuals will often perform multiple access attempts on targeted systems. Multiple

Requirements and Testing Procedures		Guidance
Customized Approach Objective	10.2.1.4 Examine audit log configurations and log data to verify that invalid logical access attempts are captured.	invalid login attempts may be an indication of an unauthorized user's attempts to "brute force" or guess a password.
Records of all invalid access attempts are captured.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 10.2.1.5 Audit logs capture all changes to identification and authentication credentials including, but not limited to: • Creation of new accounts. • Elevation of privileges. • All changes, additions, or deletions to accounts with administrative access.	Defined Approach Testing Procedures 10.2.1.5 Examine audit log configurations and log data to verify that changes to identification and authentication credentials are captured in accordance with all elements specified in this requirement.	Purpose Logging changes to authentication credentials (including elevation of privileges, additions, and deletions of accounts with administrative access) provides residual evidence of activities. Malicious users may attempt to manipulate authentication credentials to bypass them or impersonate a valid account.
Customized Approach Objective Records of all changes to identification and authentication credentials are captured.		
Defined Approach Requirements 10.2.1.6 Audit logs capture the following: • All initialization of new audit logs, and • All starting, stopping, or pausing of the existing audit logs.	Defined Approach Testing Procedures 10.2.1.6 Examine audit log configurations and log data to verify that all elements specified in this requirement are captured.	Purpose Turning off or pausing audit logs before performing illicit activities is common practice for malicious users who want to avoid detection. Initialization of audit logs could indicate that that a user disabled the log function to hide their actions.
Customized Approach Objective Records of all changes to audit log activity status are captured.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 10.2.1.7 Audit logs capture all creation and deletion of system-level objects.	Defined Approach Testing Procedures 10.2.1.7 Examine audit log configurations and log data to verify that creation and deletion of system level objects is captured.	Purpose Malicious software, such as malware, often creates or replaces system-level objects on the target system to control a particular function or operation on that system. By logging when system-level objects are created or deleted, it will be easier to determine whether such modifications were authorized.
Customized Approach Objective Records of alterations that indicate a system has been modified from its intended functionality are captured.		
Defined Approach Requirements 10.2.2 Audit logs record the following details for each auditable event: • User identification. • Type of event. • Date and time. • Success and failure indication. • Origination of event. • Identity or name of affected data, system component, resource, or service (for example, name and protocol).	Defined Approach Testing Procedures 10.2.2 Interview personnel and examine audit log configurations and log data to verify that all elements specified in this requirement are included in log entries for each auditable event (from 10.2.1.1 through 10.2.1.7).	Purpose By recording these details for the auditable events at 10.2.1.1 through 10.2.1.7, a potential compromise can be quickly identified, with sufficient detail to facilitate following up on suspicious activities.
Customized Approach Objective Sufficient data to be able to identify successful and failed attempts and who, what, when, where, and how for each event listed in requirement 10.2.1 are captured.		

Requirements and Testing Procedures		Guidance
10.3 Audit logs are protected from destruction and unauthorized modifications.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
10.3.1 Read access to audit logs files is limited to those with a job-related need.	10.3.1 Interview system administrators and examine system configurations and privileges to verify that only individuals with a job-related need have read access to audit log files.	Audit log files contain sensitive information, and read access to the log files must be limited only to those with a valid business need. This access includes audit log files on the originating systems as well as anywhere else they are stored. Good Practice Adequate protection of the audit logs includes strong access control that limits access to logs based on “need to know” only and the use of physical or network segregation to make the logs harder to find and modify.
Customized Approach Objective		
Stored activity records cannot be accessed by unauthorized personnel.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 10.3.2 Audit log files are protected to prevent modifications by individuals.	Defined Approach Testing Procedures 10.3.2 Examine system configurations and privileges and interview system administrators to verify that current audit log files are protected from modifications by individuals via access control mechanisms, physical segregation, and/or network segregation.	Purpose Often a malicious individual who has entered the network will try to edit the audit logs to hide their activity. Without adequate protection of audit logs, their completeness, accuracy, and integrity cannot be guaranteed, and the audit logs can be rendered useless as an investigation tool after a compromise. Therefore, audit logs should be protected on the originating systems as well as anywhere else they are stored. Good Practice Entities should attempt to prevent logs from being exposed in public-accessible locations.
Customized Approach Objective Stored activity records cannot be modified by personnel.		
Defined Approach Requirements 10.3.3 Audit log files, including those for external-facing technologies, are promptly backed up to a secure, central, internal log server(s) or other media that is difficult to modify.	Defined Approach Testing Procedures 10.3.3 Examine backup configurations or log files to verify that current audit log files, including those for external-facing technologies, are promptly backed up to a secure, central, internal log server(s) or other media that is difficult to modify.	Purpose Promptly backing up the logs to a centralized log server or media that is difficult to alter keeps the logs protected, even if the system generating the logs becomes compromised. Writing logs from external-facing technologies such as wireless, network security controls, DNS, and mail servers, reduces the risk of those logs being lost or altered. Good Practice Each entity determines the best way to back up log files, whether via one or more centralized log servers or other secure media. Logs may be written directly, offloaded, or copied from external systems to the secure internal system or media.
Customized Approach Objective Stored activity records are secured and preserved in a central location to prevent unauthorized modification.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements 10.3.4 File integrity monitoring or change-detection mechanisms is used on audit logs to ensure that existing log data cannot be changed without generating alerts.	Defined Approach Testing Procedures 10.3.4 Examine system settings, monitored files, and results from monitoring activities to verify the use of file integrity monitoring or change-detection software on audit logs.	Purpose File integrity monitoring or change-detection systems check for changes to critical files and notify when such changes are identified. For file integrity monitoring purposes, an entity usually monitors files that do not regularly change, but when changed, indicate a possible compromise.
Customized Approach Objective Stored activity records cannot be modified without an alert being generated.		Good Practice Software used to monitor changes to audit logs should be configured to provide alerts when existing log data or files are changed or deleted. However, new log data being added to an audit log should not generate an alert.

Requirements and Testing Procedures		Guidance
10.4 Audit logs are reviewed to identify anomalies or suspicious activity.		
Defined Approach Requirements 10.4.1 The following audit logs are reviewed at least once daily: • All security events. • Logs of all system components that store, process, or transmit CHD and/or SAD. • Logs of all critical system components. • Logs of all servers and system components that perform security functions (for example, network security controls, intrusion-detection systems/intrusion-prevention systems (IDS/IPS), authentication servers).	Defined Approach Testing Procedures 10.4.1.a Examine security policies and procedures to verify that processes are defined for reviewing all elements specified in this requirement at least once daily. 10.4.1.b Observe processes and interview personnel to verify that all elements specified in this requirement are reviewed at least once daily	Purpose Many breaches occur months before being detected. Regular log reviews mean incidents can be quickly identified and proactively addressed. Good Practice Checking logs daily (7 days a week, 365 days a year, including holidays) minimizes the amount of time and exposure of a potential breach. Log harvesting, parsing, and alerting tools, centralized log management systems, event log analyzers, and security information and event management (SIEM) solutions are examples of automated tools that can be used to meet this requirement. Daily review of security events—for example, notifications or alerts that identify suspicious or anomalous activities—as well as logs from critical system components, and logs from systems that perform security functions, such as firewalls, IDS/IPS, file integrity monitoring (FIM) systems, etc., is necessary to identify potential issues. The determination of “security event” will vary for each organization and may include consideration for the type of technology, location, and function of the device. Organizations may also wish to maintain a baseline of “normal” traffic to help identify anomalous behavior. An entity that uses third-party service providers to perform log review services is responsible to provide context about the entity’s environment to the service providers, so it understands the entity’s environment, has a baseline of “normal” traffic for the entity, and can detect potential security issues and provide accurate exceptions and anomaly notifications.
Customized Approach Objective Potentially suspicious or anomalous activities are quickly identified to minimize impact.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
10.4.1.1 Automated mechanisms are used to perform audit log reviews.	10.4.1.1 Examine log review mechanisms and interview personnel to verify that automated mechanisms are used to perform log reviews.	Manual log reviews are difficult to perform, even for one or two systems, due to the amount of log data that is generated. However, using log harvesting, parsing, and alerting tools, centralized log management systems, event log analyzers, and security information and event management (SIEM) solutions can help facilitate the process by identifying log events that need to be reviewed. Good Practice Establishing a baseline of normal audit activity patterns is critical to the effectiveness of an automated log review mechanism. The analysis of new audit activity against the established baseline can significantly improve the identification of suspicious or anomalous activities. The entity should keep logging tools aligned with any changes in their environment by periodically reviewing tool settings and updating settings to reflect any changes. Further Information Refer to the Information Supplement: <i>Effective Daily Log Monitoring</i> for additional guidance.
Customized Approach Objective		
Potentially suspicious or anomalous activities are identified via a repeatable and consistent mechanism.		
Applicability Notes		
<i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Periodic review of logs for all other system components (not specified in Requirement 10.4.1) helps to identify indications of potential issues or attempts to access critical systems via less-critical systems.
10.4.2 Logs of all other system components (those not specified in Requirement 10.4.1) are reviewed periodically.	10.4.2.a Examine security policies and procedures to verify that processes are defined for reviewing logs of all other system components periodically.	
	10.4.2.b Examine documented results of log reviews and interview personnel to verify that log reviews are performed periodically.	
Customized Approach Objective		
Potentially suspicious or anomalous activities for other system components (not included in 10.4.1) are reviewed in accordance with the entity's identified risk.		
Applicability Notes		
This requirement is applicable to all other in-scope system components not included in Requirement 10.4.1.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Entities can determine the optimum period to review these logs based on criteria such as the complexity of each entity's environment, the number of types of systems that are required to be evaluated, and the functions of such systems.
10.4.2.1 The frequency of periodic log reviews for all other system components (not defined in Requirement 10.4.1) is defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1	10.4.2.1.a Examine the entity's targeted risk analysis for the frequency of periodic log reviews for all other system components (not defined in Requirement 10.4.1) to verify the risk analysis was performed in accordance with all elements specified at Requirement 12.3.1.	
Customized Approach Objective Log reviews for lower-risk system components are performed at a frequency that addresses the entity's risk.	10.4.2.1.b Examine documented results of periodic log reviews of all other system components (not defined in Requirement 10.4.1) and interview personnel to verify log reviews are performed at the frequency specified in the entity's targeted risk analysis performed for this requirement.	
Applicability Notes <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose If exceptions and anomalies identified during the log-review process are not investigated, the entity may be unaware of unauthorized and potentially malicious activities occurring within their network. Good Practice Entities should consider how to address the following when developing their processes for defining and managing exceptions and anomalies: • How log review activities are recorded, • How to rank and prioritize exceptions and anomalies, • What procedures should be in place to report and escalate exceptions and anomalies, and • Who is responsible for investigating and for any remediation tasks.
10.4.3 Exceptions and anomalies identified during the review process are addressed.	10.4.3.a Examine security policies and procedures to verify that processes are defined for addressing exceptions and anomalies identified during the review process.	
Customized Approach Objective Suspicious or anomalous activities are addressed.	10.4.3.b Observe processes and interview personnel to verify that, when exceptions and anomalies are identified, they are addressed.	

Requirements and Testing Procedures		Guidance
10.5 Audit log history is retained and available for analysis.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Retaining historical audit logs for at least 12 months is necessary because compromises often go unnoticed for significant lengths of time. Having centrally stored log history allows investigators to better determine the length of time a potential breach was occurring, and the possible system(s) impacted. By having three months of logs immediately available, an entity can quickly identify and minimize impact of a data breach. Examples Methods that allow logs to be immediately available include storing logs online, archiving logs, or restoring logs quickly from backups.
10.5.1 Retain audit log history for at least 12 months, with at least the most recent three months immediately available for analysis.	10.5.1.a Examine documentation to verify that the following is defined: - Audit log retention policies. - Procedures for retaining audit log history for at least 12 months, with at least the most recent three months immediately available online.	
	10.5.1.b Examine configurations of audit log history, interview personnel and examine audit logs to verify that audit logs history is retained for at least 12 months.	
Customized Approach Objective	10.5.1.c Interview personnel and observe processes to verify that at least the most recent three months' audit log history is immediately available for analysis.	
Historical records of activity are available immediately to support incident response and are retained for at least 12 months.		

Requirements and Testing Procedures		Guidance
10.6 Time-synchronization mechanisms support consistent time settings across all systems.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose Time synchronization technology is used to synchronize clocks on multiple systems. When clocks are not properly synchronized, it can be difficult, if not impossible, to compare log files from different systems and establish an exact sequence of events, which is crucial for forensic analysis following a breach. For post-incident forensics teams, the accuracy and consistency of time across all systems and the time of each activity are critical in determining how the systems were compromised. Examples Network Time Protocol (NTP) is one example of time-synchronization technology.
10.6.1 System clocks and time are synchronized using time-synchronization technology.	10.6.1 Examine system configuration settings to verify that time-synchronization technology is implemented and kept current.	
Customized Approach Objective		
Common time is established across all systems.		
Applicability Notes		
Keeping time-synchronization technology current includes managing vulnerabilities and patching the technology according to PCI DSS Requirements 6.3.1 and 6.3.3.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
10.6.2 Systems are configured to the correct and consistent time as follows: - One or more designated time servers are in use. - Only the designated central time server(s) receives time from external sources. - Time received from external sources is based on International Atomic Time or Coordinated Universal Time (UTC). - The designated time server(s) accept time updates only from specific industry-accepted external sources. - Where there is more than one designated time server, the time servers peer with one another to keep accurate time. - Internal systems receive time information only from designated central time server(s).	10.6.2 Examine system configuration settings for acquiring, distributing, and storing the correct time to verify the settings are configured in accordance with all elements specified in this requirement.	Using reputable time servers is a critical component of the time synchronization process. Accepting time updates from specific, industry-accepted external sources helps prevent a malicious individual from changing time settings on systems. Good Practice Another option to prevent unauthorized use of internal time servers is to encrypt updates with a symmetric key and create access control lists that specify the IP addresses of client machines that will be provided with the time updates.
Customized Approach Objective		
The time on all systems is accurate and consistent.		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
10.6.3 Time synchronization settings and data are protected as follows: - Access to time data is restricted to only personnel with a business need. - Any changes to time settings on critical systems are logged, monitored, and reviewed.	10.6.3.a Examine system configurations and time-synchronization settings to verify that access to time data is restricted to only personnel with a business need.	Attackers will try to change time configurations to hide their activity. Therefore, restricting the ability to change or modify time synchronization configurations or the system time to administrators will lessen the probability of an attacker successfully changing time configurations.
Customized Approach Objective System time settings cannot be modified by unauthorized personnel.	10.6.3.b Examine system configurations and time synchronization settings and logs and observe processes to verify that any changes to time settings on critical systems are logged, monitored, and reviewed.	

Requirements and Testing Procedures		Guidance
10.7 Failures of critical security control systems are detected, reported, and responded to promptly.		
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
10.7.1 Additional requirement for service providers only: Failures of critical security control systems are detected, alerted, and addressed promptly, including but not limited to failure of the following critical security control systems: • Network security controls. • IDS/IPS. • FIM. • Anti-malware solutions. • Physical access controls. • Logical access controls. • Audit logging mechanisms. • Segmentation controls (if used).	10.7.1.a Additional testing procedure for service provider assessments only: Examine documentation to verify that processes are defined for the prompt detection and addressing of failures of critical security control systems, including but not limited to failure of all elements specified in this requirement.	Purpose Without formal processes to detect and alert when critical security controls fail, failures may go undetected for extended periods and provide attackers ample time to compromise system components and steal account data from the CDE. Good Practice The specific types of failures may vary, depending on the function of the device system component and technology in use. Typical failures include a system ceasing to perform its security function or not functioning in its intended manner, such as a firewall erasing all its rules or going offline.
Customized Approach Objective Failures in critical security control systems are promptly identified and addressed.	10.7.1.b Additional testing procedure for service provider assessments only: Observe detection and alerting processes and interview personnel to verify that failures of critical security control systems are detected and reported, and that failure of a critical security control results in the generation of an alert.	
Applicability Notes This requirement applies only when the entity being assessed is a service provider. <i>This requirement will be superseded by Requirement 10.7.2 as of 31 March 2025.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
10.7.2 Failures of critical security control systems are detected, alerted, and addressed promptly, including but not limited to failure of the following critical security control systems: • Network security controls. • IDS/IPS. • Change-detection mechanisms. • Anti-malware solutions. • Physical access controls. • Logical access controls. • Audit logging mechanisms. • Segmentation controls (if used). • Audit log review mechanisms. • Automated security testing tools (if used).	10.7.2.a Examine documentation to verify that processes are defined for the prompt detection and addressing of failures of critical security control systems, including but not limited to failure of all elements specified in this requirement. 10.7.2.b Observe detection and alerting processes and interview personnel to verify that failures of critical security control systems are detected and reported, and that failure of a critical security control results in the generation of an alert.	Without formal processes to detect and alert when critical security controls fail, failures may go undetected for extended periods and provide attackers ample time to compromise system components and steal account data from the CDE. Good Practice The specific types of failures may vary, depending on the function of the device system component and technology in use. However, typical failures include a system no longer performing its security function or not functioning in its intended manner—for example, a firewall erasing its rules or going offline.
Customized Approach Objective		
Failures in critical security control systems are promptly identified and addressed.		
Applicability Notes		
<i>This requirement applies to all entities, including service providers, and will supersede Requirement 10.7.1 as of 31 March 2025. It includes two additional critical security control systems not in Requirement 10.7.1.</i> <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	Defined Approach Testing Procedures	Purpose
10.7.3 Failures of any critical security control systems are responded to promptly, including but not limited to: - Restoring security functions. - Identifying and documenting the duration (date and time from start to end) of the security failure. - Identifying and documenting the cause(s) of failure and documenting required remediation. - Identifying and addressing any security issues that arose during the failure. - Determining whether further actions are required as a result of the security failure. - Implementing controls to prevent the cause of failure from reoccurring. - Resuming monitoring of security controls.	10.7.3.a Examine documentation and interview personnel to verify that processes are defined and implemented to respond to a failure of any critical security control system and include at least all elements specified in this requirement. 10.7.3.b Examine records to verify that failures of critical security control systems are documented to include: - Identification of cause(s) of the failure. - Duration (date and time start and end) of the security failure. - Details of the remediation required to address the root cause.	If alerts from failures of critical security control systems are not responded to quickly and effectively, attackers may use this time to insert malicious software, gain control of a system, or steal data from the entity's environment. Good Practice Documented evidence (for example, records within a problem management system) should provide support that processes and procedures are in place to respond to security failures. In addition, personnel should be aware of their responsibilities in the event of a failure. Actions and responses to the failure should be captured in the documented evidence.
Customized Approach Objective		
Failures of critical security control systems are analyzed, contained, and resolved, and security controls restored to minimize impact. Resulting security issues are addressed, and measures taken to prevent reoccurrence. <i>(continued on next page)</i>		

Requirements and Testing Procedures		Guidance
Applicability Notes This requirement applies only when the entity being assessed is a service provider until 31 March 2025, after which this requirement will apply to all entities. <i>This is a current v3.2.1 requirement that applies to service providers only. However, this requirement is a best practice for all other entities until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>		